A-LIGN

A-LIGN.com

Type 2 SOC 2

Prepared for:
MERGE

Year:
2025

MERGE

REPORT ON MERGE'S DESCRIPTION OF ITS SYSTEM AND ON THE SUITABILITY OF THE DESIGN AND OPERATING EFFECTIVENESS OF ITS CONTROLS RELEVANT TO SECURITY

Pursuant to Reporting on System and Organization Controls 2 (SOC 2)
Type 2 examination performed under AT-C 105 and AT-C 205

November 1, 2024 to October 31, 2025

Table of Contents

SECTION 1 ASSERTION OF MERGE MANAGEMENT 1

SECTION 2 INDEPENDENT SERVICE AUDITOR'S REPORT 3

SECTION 3 MERGE'S DESCRIPTION OF ITS MARKETING CONSULTING AND JETO SAAS SERVICES SYSTEM THROUGHOUT THE PERIOD NOVEMBER 1, 2024 TO OCTOBER 31, 2025 7

OVERVIEW OF OPERATIONS 8
- Company Background 8
- Description of Services Provided 8
- Principal Service Commitments and System Requirements 8
- Components of the System 10
- Boundaries of the System 14

RELEVANT ASPECTS OF THE CONTROL ENVIRONMENT, RISK ASSESSMENT PROCESS, INFORMATION AND COMMUNICATION, AND MONITORING 15
- Control Environment 15
- Risk Assessment Process 17
- Information and Communications Systems 17
- Monitoring Controls 18
- Changes to the System in the Last 12 Months 18
- Incidents in the Last 12 Months 18
- Criteria Not Applicable to the System 18
- Subservice Organizations 18

COMPLEMENTARY USER ENTITY CONTROLS 20

TRUST SERVICES CATEGORIES 20

SECTION 4 TRUST SERVICES CATEGORY, CRITERIA, RELATED CONTROLS, AND TESTS OF CONTROLS 22

GUIDANCE REGARDING TRUST SERVICES CATEGORY, CRITERIA, RELATED CONTROLS, AND TESTS OF CONTROLS 23

CONTROL ACTIVITIES SPECIFIED BY THE SERVICE ORGANIZATION 24
- TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY 24

SECTION 5 OTHER INFORMATION PROVIDED BY THE SERVICE ORGANIZATION 134

SUMMARY OF TESTING EXCEPTIONS 135

SECTION 1

ASSERTION OF MERGE MANAGEMENT

Proprietary and Confidential

ASSERTION OF MERGE MANAGEMENT

December 5, 2025

We have prepared the accompanying description of MERGE's ('the Company') Marketing Consulting and Jeto SaaS Services System titled "MERGE's Description of Its Marketing Consulting and Jeto SaaS Services System throughout the period November 1, 2024 to October 31, 2025" (description) based on the criteria for a description of a service organization's system in DC section 200, *2018 Description Criteria for a Description of a Service Organization's System in a SOC 2® Report* (AICPA, *Description Criteria*) (description criteria). The description is intended to provide report users with information about the Marketing Consulting and Jeto SaaS Services System that may be useful when assessing the risks arising from interactions with MERGE's system, particularly information about system controls that MERGE has designed, implemented, and operated to provide reasonable assurance that its service commitments and system requirements were achieved based on the trust services criteria relevant to Security (applicable trust services criteria) set forth in TSP section 100, *2017 Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy* (AICPA, *Trust Services Criteria*).

MERGE uses Amazon Web Services, Inc ('AWS') and Google Cloud Platform ('GCP') to provide cloud hosting services (collectively, the 'subservice organizations'). The description indicates that complementary subservice organization controls that are suitably designed and operating effectively are necessary, along with controls at MERGE, to achieve MERGE's service commitments and system requirements based on the applicable trust services criteria. The description presents MERGE's controls, the applicable trust services criteria, and the types of complementary subservice organization controls assumed in the design of MERGE's controls. The description does not disclose the actual controls at the subservice organizations.

The description indicates that complementary user entity controls that are suitably designed and operating effectively are necessary, along with controls at MERGE, to achieve MERGE's service commitments and system requirements based on the applicable trust services criteria. The description presents MERGE's controls, the applicable trust services criteria, and the complementary user entity controls assumed in the design of MERGE's controls.

We confirm, to the best of our knowledge and belief, that:

a. the description presents MERGE's Marketing Consulting and Jeto SaaS Services System that was designed and implemented throughout the period November 1, 2024 to October 31, 2025, in accordance with the description criteria.
b. the controls stated in the description were suitably designed throughout the period November 1, 2024 to October 31, 2025, to provide reasonable assurance that MERGE's service commitments and system requirements would be achieved based on the applicable trust services criteria, if its controls operated effectively throughout that period, and if the subservice organization and user entities applied the complementary controls assumed in the design of MERGE's controls throughout that period.
c. the controls stated in the description operated effectively throughout the period November 1, 2024 to October 31, 2025, to provide reasonable assurance that MERGE's service commitments and system requirements were achieved based on the applicable trust services criteria, if complementary subservice organization controls and complementary user entity controls assumed in the design of MERGE's controls operated effectively throughout that period.

David Desrosiers
SVP Marketing Technology
MERGE

Proprietary and Confidential

SECTION 2

INDEPENDENT SERVICE AUDITOR'S REPORT

A-LIGN

INDEPENDENT SERVICE AUDITOR'S REPORT

To: MERGE

Scope

We have examined MERGE's accompanying description of its Marketing Consulting and Jeto SaaS Services System titled "MERGE's Description of Its Marketing Consulting and Jeto SaaS Services System throughout the period November 1, 2024 to October 31, 2025" (description) based on the criteria for a description of a service organization's system in DC section 200, *2018 Description Criteria for a Description of a Service Organization's System in a SOC 2® Report* (AICPA, *Description Criteria*), (description criteria) and the suitability of the design and operating effectiveness of controls stated in the description throughout the period November 1, 2024 to October 31, 2025, to provide reasonable assurance that MERGE's service commitments and system requirements were achieved based on the trust services criteria relevant to Security (applicable trust services criteria) set forth in TSP section 100, *2017 Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy* (AICPA, *Trust Services Criteria*).

MERGE uses AWS and GCP to provide cloud hosting services. The description indicates that complementary subservice organization controls that are suitably designed and operating effectively are necessary, along with controls at MERGE, to achieve MERGE's service commitments and system requirements based on the applicable trust services criteria. The description presents MERGE's controls, the applicable trust services criteria, and the types of complementary subservice organization controls assumed in the design of MERGE's controls. The description does not disclose the actual controls at the subservice organizations. Our examination did not include the services provided by the subservice organizations, and we have not evaluated the suitability of the design or operating effectiveness of such complementary subservice organization controls.

The description indicates that complementary user entity controls that are suitably designed and operating effectively are necessary, along with controls at MERGE, to achieve MERGE's service commitments and system requirements based on the applicable trust services criteria. The description presents MERGE's controls, the applicable trust services criteria, and the complementary user entity controls assumed in the design of MERGE's controls. Our examination did not include such complementary user entity controls and we have not evaluated the suitability of the design or operating effectiveness of such controls.

The information included in Section 5, "Other Information Provided by the Service Organization," is presented by MERGE management to provide additional information and is not a part of the description. Information about MERGE's management's response to testing exceptions has not been subjected to the procedures applied in the examination of the description, the suitability of the design of controls, and the operating effectiveness of the controls to achieve MERGE's service commitments and system requirements based on the applicable trust services criteria.

Service Organization's Responsibilities

MERGE is responsible for its service commitments and system requirements and for designing, implementing, and operating effective controls within the system to provide reasonable assurance that MERGE's service commitments and system requirements were achieved. MERGE has provided the accompanying assertion titled "Assertion of MERGE Management" (assertion) about the description and the suitability of design and operating effectiveness of controls stated therein. MERGE is also responsible for preparing the description and assertion, including the completeness, accuracy, and method of presentation of the description and assertion; providing the services covered by the description; selecting the applicable trust services criteria and stating the related controls in the description; and identifying the risks that threaten the achievement of the service organization's service commitments and system requirements.

Service Auditor's Responsibilities

Our responsibility is to express an opinion on the description and on the suitability of design and operating effectiveness of controls stated in the description based on our examination. Our examination was conducted in accordance with attestation standards established by the American Institute of Certified Public Accountants. Those standards require that we plan and perform our examination to obtain reasonable assurance about whether, in all material respects, the description is presented in accordance with the description criteria and the controls stated therein were suitably designed and operated effectively to provide reasonable assurance that the service organization's service commitments and system requirements were achieved based on the applicable trust services criteria. We believe that the evidence we obtained is sufficient and appropriate to provide a reasonable basis for our opinion.

An examination of the description of a service organization's system and the suitability of the design and operating effectiveness of controls involves the following:

- Obtaining an understanding of the system and the service organization's service commitments and system requirements
- Assessing the risks that the description is not presented in accordance with the description criteria and that controls were not suitably designed or did not operate effectively
- Performing procedures to obtain evidence about whether the description is presented in accordance with the description criteria
- Performing procedures to obtain evidence about whether controls stated in the description were suitably designed to provide reasonable assurance that the service organization achieved its service commitments and system requirements based on the applicable trust services criteria
- Testing the operating effectiveness of controls stated in the description to provide reasonable assurance that the service organization achieved its service commitments and system requirements based on the applicable trust services criteria
- Evaluating the overall presentation of the description

Our examination also included performing such other procedures as we considered necessary in the circumstances.

Independence and Ethical Responsibilities

We are required to be independent and to meet our other ethical responsibilities in accordance with relevant ethical requirements relating to the examination engagement.

Inherent Limitations

The description is prepared to meet the common needs of a broad range of report users and may not, therefore, include every aspect of the system that individual users may consider important to meet their informational needs.

There are inherent limitations in the effectiveness of any system of internal control, including the possibility of human error and the circumvention of controls.

Because of their nature, controls may not always operate effectively to provide reasonable assurance that the service organization's service commitments and system requirements are achieved based on the applicable trust services criteria. Also, the projection to the future of any conclusions about the suitability of the design and operating effectiveness of controls is subject to the risk that controls may become inadequate because of changes in conditions or that the degree of compliance with the policies or procedures may deteriorate.

Description of Tests of Controls

The specific controls we tested and the nature, timing, and results of those tests are listed in Section 4.

Opinion

In our opinion, in all material respects,

a. the description presents MERGE's Marketing Consulting and Jeto SaaS Services System that was designed and implemented throughout the period November 1, 2024 to October 31, 2025, in accordance with the description criteria.
b. the controls stated in the description were suitably designed throughout the period November 1, 2024 to October 31, 2025, to provide reasonable assurance that MERGE's service commitments and system requirements would be achieved based on the applicable trust services criteria, if its controls operated effectively throughout that period and if the subservice organization and user entities applied the complementary controls assumed in the design of MERGE's controls throughout that period.
c. the controls stated in the description operated effectively throughout the period November 1, 2024 to October 31, 2025, to provide reasonable assurance that MERGE's service commitments and system requirements were achieved based on the applicable trust services criteria, if complementary subservice organization controls and complementary user entity controls assumed in the design of MERGE's controls operated effectively throughout that period.

Restricted Use

This report, including the description of tests of controls and results thereof in Section 4, is intended solely for the information and use of MERGE, user entities of MERGE's Marketing Consulting and Jeto SaaS Services System during some or all of the period November 1, 2024 to October 31, 2025, business partners of MERGE subject to risks arising from interactions with the Marketing Consulting and Jeto SaaS Services System, practitioners providing services to such user entities and business partners, prospective user entities and business partners, and regulators who have sufficient knowledge and understanding of the following:

- The nature of the service provided by the service organization
- How the service organization's system interacts with user entities, business partners, subservice organizations, and other parties
- Internal control and its limitations
- Complementary user entity controls and complementary subservice organization controls and how those controls interact with the controls at the service organization to achieve the service organization's service commitments and system requirements
- User entity responsibilities and how they may affect the user entity's ability to effectively use the service organization's services
- The applicable trust services criteria
- The risks that may threaten the achievement of the service organization's service commitments and system requirements and how controls address those risks

This report is not intended to be, and should not be, used by anyone other than these specified parties.

A-LIGN ASSURANCE

Tampa, Florida
December 5, 2025

SECTION 3

MERGE'S DESCRIPTION OF ITS MARKETING CONSULTING AND JETO SAAS SERVICES SYSTEM THROUGHOUT THE PERIOD NOVEMBER 1, 2024 TO OCTOBER 31, 2025

OVERVIEW OF OPERATIONS

Company Background

MERGE (formerly Perkuto), a marketing operations agency and marketing operations products developer, helps enterprise and high-growth organizations expand team capacity and accelerate the value of Marketo. From advising on best practices to increasing campaign volume to resolving integration challenges, Merge helps leading brands add marketing momentum, improve operational efficiency, and deliver predictable outcomes. Merge's exclusive Marketo focus and deep platform expertise, combined with a methodical process, ensure projects are done right, on time, and budget.

MERGE is an Adobe Marketo Engage Platinum Partner. MERGE has received multiple recognitions, such as Great Place to Work Quebec 2020 and Canada's Fastest-Growing Companies 2020.

Perkuto was founded in 2023 and is now MERGE with field offices in Montreal and across the U.S.

Description of Services Provided

MERGE comprises two divisions: Services and Technologies. Both divisions solve efficiency challenges for enterprise organizations and are centered around accelerating the value of Marketo. The services each division offers include:

MERGE Services

- Marketo consulting: strategic advisement, platform infrastructure, campaign execution, marketing operations best practices
- Data integration with Marketo: enabling advanced tech integrations and resolving sync challenges
- Data integration with Workato: enabling data flows between technologies agency-wide
- Marketing automation platform migrations to Marketo
- GDPR/CASL/CCPA marketing alignment for regulation compliance
- Marketo reporting and analytics, including Bizible implementation, set-up, and consultation

MERGE Technologies

- Jeto: a proprietary tool that simplifies and automates Marketo campaign execution
- Digesto: a proprietary tool that automates content distribution to defined streams, using Marketo

Principal Service Commitments and System Requirements

MERGE Services are defined and documented in Statements of Work, approved by clients.

Consulting services can be broken down into two separate categories:

Strategy and Infrastructure Projects **-** these services include a high level of discovery and architecture to understand, identify and offer recommendations for addressing current business challenges. The outcome of strategic infrastructure consulting will include a technical design document containing definitions and parameters for the proposed solutions. It will often include new functionality created within the Marketo platform.

Managed Services - these services are more transactional in nature. The client will identify a list of tasks to be completed, and the consultant will access the client's Marketo instance to complete the work. This category may also include any work required by the MERGE creative team, including updates to e-mails and landing page assets.

Both categories of service deliverables are tested before deployment to ensure that requirements are met.

MERGE Technologies offers two Software as a Service (SaaS) Products. Digesto, which allows the automation of the distribution of Newsfeeds and Newsletters via Marketo e-mails, and Jeto which streamlines, simplifies, and automates marketing campaign execution for Marketo users. At a high level this is the process through which each project is planned, prioritized, executed, and delivered:

1. Review Strategy (Quarterly or as needed):
    - 1.1 Client Discovery (C, I, R from C.I.R.C.L.E.S Methodology).
    - 1.2 Summarize Context.
    - 1.3 Identify Customer Profile.
    - 1.4 Report Customer Needs / User Stories (Product Interviews, Sales Feedback, User Ideas Portal, Stakeholders Input).
2. Product Design (L, E, S from C.I.R.C.L.E.S Methodology):
    - 2.1 Complete Scope - List Solutions Included and excluded features.
    - 2.2 Complete Estimates of Features Considered.
    - 2.3 Confirm Prioritization and Alignment\Review of Roadmap.
    - 2.4 Solution Acceptance Criteria.
    - 2.5 UI/UX Design.
    - 2.6 UAT/Get Customer Validation.
3. Technical Design:
    - 3.1 Technical requirements are completed by the software architect.
    - 3.2 Technical feasibility analysis is confirmed.
    - 3.3 If required, proof of concept is completed.
    - 3.4 Estimates of features considered are reviewed considering the refined technical requirements.
4. Execute:
    - 4.1 Develop.
    - 4.2 Submit Pull Request.
    - 4.3 Peer Review.
    - 4.4 Depot to Staging.
    - 4.5 Update Confluence Product Documentation with changes.
5. QA and Security:
    - 5.1 Unit Testing.
    - 5.2 Functional Testing (incl regression tests for new features + Improvements).
    - 5.3 Vulnerability Scanning.
    - 5.4 Changes Risk Assessment.
6. Deploy to Production \ Launch:
    - 6.1 Internal Training.
    - 6.2 Pre-release notification.
    - 6.3 Release Notes and Update Help Documentation.
    - 6.4 Software Release.
    - 6.5 Customer online training and Q&A (Office Hour).

Components of the System

Infrastructure

Primary infrastructure used to provide MERGE's Marketing Consulting and Jeto SaaS Services System includes the following:

Primary Infrastructure		
Hardware	**Type**	**Purpose**
Webservers	AWS (Amazon Web Services) Elastic Cloud Compute (EC2)	Host web applications and supporting processes
Database servers	AWS Relational Database Service (RDS)	Store data to applications
Data storage	AWS Elastic Block Store (EBS) and Simple Storage Service (S3)	Store objects
Load balancers	AWS Elastic Load Balancing (ELB)	High Availability and redundancy for applications
MacBook Pro	Laptop	Access all applications to develop, test and deploy the products in the cloud

Software

Primary software used to provide MERGE's Marketing Consulting and Jeto SaaS Services System includes the following:

Primary Software for MERGE Services		
Software	**Operating System**	**Purpose**
LiquidPlanner	WebApp	Project management tool used to track project progress, consultant utilization, as well as client billable hours
Marketo	WebApp	Marketing automation platform on which MERGE consulting services are delivered (MERGE will access client Marketo instances)
Google Workspace	WebApp	Suite of tools utilized for sending and receiving e-mail, as a document repository, a virtual calendar, as well as a suite of productivity tools (spreadsheets, word processor, etc.)
1Password	WebApp	A password management system used to store client application credentials
Slack	WebApp	Instant messaging platform used to collaborate both internally and with clients on client projects
Zoom	WebApp	Video conference platform used for audio communications with clients (project updates, discovery sessions, etc.)

Primary Software for MERGE Services		
Software	**Operating System**	**Purpose**
Calendly	WebApp	Calendar application allowing clients to proactively schedule meetings with the members of the MERGE team
Lucid Chart	WebApp	Diagramming software used to create new processes flows and illustrate expected project functionality
Cisco Meraki virtual private network (VPN)	WebApp	The VPN platform allows MERGE to connect to certain client platforms where IP whitelisting and other security protocols may be in place
E-mail on Acid	WebApp	Tool used to render e-mails on multiple e-mail clients at once to determine if any corrections to e-mail assets are required
Jira	WebApp	Software Development Project Management
AWS	AWS Linux	AWS RDS - Databases (Jeto, Custom Projects) AWS CloudFront Application Content Distribution AWS S3 Static Web Hosting Servers AWS EC2 Application Server (Until Docker\Containerized in place - Mid 2021) AWS ECS Application Server (Docker\Containerized Environment - Mid 2021 forward) AWS Quicksight - Reporting on Application Usage and Data AWS CloudWatch - AWS Systems Usage and Performance Monitoring
Heroku	Cloud Computing	Database Hosting for Digesto
GitHub	Linux	Code repository and version control
New Relic	WebApp	Server Usage and Performance Monitoring
Rapid7	WebApp	Application Logs for Monitoring and Technical Support
Auth0	WebApp	Authentication Management Platform, used for Jeto and single sign-on (SSO) implementations
Chargebee	Payment Services	Ecommerce Subscription management platform
Stripe	Payment Services	Payment Gateway for Digesto Ecommerce

People

MERGE Services: the team that delivers consulting services to clients. They will provide strategic and execution-type consulting services on the Marketo platform (and adjacent technologies). These services will include architecting solutions for business:

- The EVP of Operations oversees the delivery team and is accountable for ensuring performance and availability of resources to complete the contracts delivered by the sales team
- The Director of operations is responsible for forecasting and cross-team collaboration and is a point of contact within the delivery team for sales, marketing, and the executive team. The role also oversees all platforms used by the team. It works on audits and overall operational processes
- Director of consulting services directly oversees the consultants and project managers, and are responsible for project management and consultant process, individual team member performance, creating and documenting new delivery training opportunities, and effective delivery of projects

- Director of solution architecture. Oversees the Solutions architecture team, participating in pre-sales and scoping activities, identifying, and creating new products for MERGE's catalogue, reviewing individual team member performance
- Solutions architect. Participates in scoping and pre-sales activities, acts as subject matter experts in specific fields and can be leveraged by the consultant team to assist with complex projects
- Senior consultant. Acts as technical leads on client accounts, providing consulting services and best practice approaches to solve client business challenges within Marketo. Senior consultants create technical design documents, which contain all requirements and business objectives for which the client is looking for a solution
- Associate consultant. Will normally be paired with a Senior consultant on client accounts and will execute program builds in Marketo as per the Technical Design document created by the Senior consultant. May also act as leads on accounts that require less architecture and are more centered on execution type work
- Marketo specialist. Specialists' complete execution type work in Marketo exclusively, creating programs as per a set of instructions provided by either the Senior consultant or the Associate consultant
- Project manager. Oversee staffing of projects, ensuring projects stay on budget and on time, and provide regular updates to stakeholders, both internal and external. Project managers also review existing processes for and make recommendations based on project postmortems

MERGE Technologies: the team that delivers the SaaS product and custom software development services to clients. These services will include designing and developing software for enterprise clients:

- VP Product Engineering. Leads the product management and development teams. Involved in all phases of development, including identifying market needs, solutions design, technical specifications, quality assurance documentation and product marketing\communications. Owns the product backlog and prioritizes increments and product roadmap
- VP Customer Success. Responsible for customer satisfaction. Also, in charge of customer onboarding, customer support and helps report customer needs to the product team
- UI\UX Designer. Will design user interface and interaction for the web applications
- Frontend Developer. Is responsible for the development of web applications, mainly in regard to user interfaces and communications with the backend of the application
- Solutions Architect and Backend Developer. Is responsible for the design and architecture of web services. Will also develop web applications, mainly in regard to the database, and the processing and the services running on the application and made available to front-end clients
- Infrastructure and DevOps Specialist. Is responsible for the build and maintenance of server infrastructure for the hosting of web application and data
- Manual QA Tester. Will analyze and create manual test cases, document, and execute them to ensure that the software meets the acceptance criteria
- QA Automation Engineer. Will automate test scenarios to be executed programmatically, making sure that all the software functions and acceptance criteria are constantly met when software is updated

Data

The following is a non-exhaustive list of data to which MERGE will have access while accessing various platforms (Marketo, Salesforce, etc.):

- Personal data (name, e-mail, address, role, company, etc.)
- Sales data (open opportunities, current sales stage, purchase history, etc.)
- Client behavior and history (web pages visited, assets downloaded, newsletter subscription information, etc.)

Those data are never stored on MERGE properties. They live in the cloud within their respective SaaS providers.

MERGE Services

MERGE Services target the data stored in the Marketo Instance of the client. Those data will include the following client's lead, prospects, and client information:

- Name
- Title
- Company name
- E-mail address
- Phone Number
- E-mail sent history
- Interaction with client's website
- Interaction with client's e-mails
- Subscription information/Opt-in etc.

Those data live in the Client's SaaS systems and are never stored on MERGE's properties.

MERGE Technologies

MERGE Technologies targets data related to the user of the systems developed. Like:

- Name
- Company
- E-mail Address

Data is stored in AWS.

Processes, Policies and Procedures

MERGE has developed formal IT policies and procedures that describe logical access, computer operations, change control, and data communication standards. All teams are expected to adhere to the MERGE policies and procedures that define how services should be delivered and product developed. These are located on the company's shared drive and can be accessed by any MERGE team member.

Physical Security

Being 100% virtual, MERGE does not maintain any physical infrastructure. The in-scope system and supporting infrastructure are hosted by AWS and GCP. As such, AWS and GCP are responsible for physical security controls. Refer to the Subservice Organizations section for additional information.

Logical Access

MERGE uses role-based security architecture and requires users of the system to be identified and authenticated prior to the use of any system resources.

MERGE maintains no traditional central network, but it does use a G Suite organization for the entire company, governing access to e-mail, internal mailing lists and employees are granted access to internally used tools and services on a least-privilege basis. Individual user accounts are used, and no accounts are shared. On a per-tool basis, employees are either strongly encouraged or explicitly required to use two-factor authentication.

Access is allowed on a role-based model where modifications to the allowed access for a role follow an established change procedure. Procedures for revoking employees' access to MERGE internal tools and systems upon termination are defined and enforced. User lists and access levels for all systems are reviewed bi-annually.

MERGE performs regular user access reviews of the internal systems bi-annually.

Computer Operations - Backups

Google Workspace Backup: MERGE performs a daily cloud-based backup of Google Workspace. This includes:

- E-mail (Gmail)
- Files (Google Drive)
- Contacts
- Events detail (Google Calendar)
- Intranet (Google Sites)

AWS Backup: Backups are performed for Digesto and Jeto Databases daily. Copies of the databases are kept for 35 days for Jeto and 15 days for Digesto.

Computer Operations - Availability

MERGE has put in place Incident response policies and procedures to guide personnel in reporting and responding to information technology incidents. Procedures exist to identify, report, and act upon system security breaches and other incidents. Incident response procedures are in place to identify and respond to incidents on the network.

A publicly available status page is kept that displays ongoing and previous incidents.

MERGE performs vulnerability scans daily and applies applicable mitigations for the identified security vulnerabilities.

Change Control

MERGE enforces a change control procedure, including categorizing the change and documenting the procedure that is to be used for implementing the change. This procedure applies to production applications and production infrastructure.

MERGE enforces the use of GitHub version control software for application development. All code changes must be submitted via pull request and must be approved by at least one other qualified developer for the repository in question who did not contribute directly to the change before it can be merged into main branches. Code must also pass automated tests before it can be merged.

Data Communications

MERGE employs standard Internet gateway and security group setups for AWS resources to limit the ports that are exposed to only those required for production operations. Administrative access requires key-based authentication. All authentication attempts are logged, as are all administrative actions taken.

Boundaries of the System

The scope of this report includes MERGE's Marketing Consulting and Jeto SaaS Services System managed by the Montreal, Quebec headquarters.

This report does not include the cloud hosting services provided by AWS or GCP at various facilities.

RELEVANT ASPECTS OF THE CONTROL ENVIRONMENT, RISK ASSESSMENT PROCESS, INFORMATION AND COMMUNICATION, AND MONITORING

Control Environment

Integrity and Ethical Values

MERGE maintains policies that include a Code of Conduct and a statement that all offers of employment are contingent upon the results of a background check conducted at MERGE's discretion.

Within the first week after their start date, employees are provided a copy of the Employee Handbook, which includes the same Code of Conduct. Employees are then required to submit an acknowledgement that they have received, understand, and agree to abide by its contents.

Here is a list of specific control activities that the organization has implemented in this area:

- Formally, documented organizational policy statements and codes of conduct communicate entity values and behavioral standards to personnel
- Policies and procedures require employees sign an acknowledgment form indicating they have been given access to the employee manual and understand their responsibility for adhering to the policies and procedures contained within the manual
- A confidentiality statement agreeing not to disclose proprietary or confidential information, including client information, to unauthorized parties is a component of the employee contract
- Background checks are performed for employees as a component of the hiring process

Commitment to Competence

MERGE maintains a list of proficiencies for each member of the consulting team, identifying areas of expertise as well as growth opportunities. MERGE utilizes the following methods to ensure continued expertise as well as improving overall team abilities:

- Shadowing: MERGE actively seeks to pair consultants who are subject matter experts with consultants that are looking to improve a specific skill set on projects, where appropriate
- Training library: MERGE maintains a library (on Moodle) of best practices, referring consultants who wish to improve their skills to this platform. MERGE has also a LinkedIn learning subscription to allow all employees to have access to relevant material pertaining to their professional and personal development
- Training sessions: MERGE will regularly provide training to the delivery team on best practices through presentations on specific topics
- Certification: MERGE invests to ensure that all consultants are Marketo certified, and Project Managers are PMP Certified. MERGE also invests time and money on certification for adjacent technologies that support the overall company vision and direction
- Postmortem: MERGE will regularly review performance on client projects to identify improvements to process or training opportunities for the team or individual consultants
- Management has considered the competence levels for any particular job and translated this into required skills and knowledge levels captured in structured job descriptions

Management's Philosophy and Operating Style

MERGE management assesses regulatory requirements on an ongoing basis. Potential risks are gathered as they are identified and are reviewed quarterly by executive management, ensuring that all risks are evaluated for probability and impact on the business and prioritized for mitigation efforts. Of course, when a severe risk is discovered, the evaluation and mitigation is discussed immediately.

MERGE reviews its policies at least annually and whenever deemed essential to provide the proper guidance. Management communicates changes internally through regular communication: internal memo or monthly all-hands meeting.

MERGE has implemented the following control activities:

- Executive management monitors trusted sources to identify regulatory and industry changes affecting the services provided
- Executive management holds weekly and quarterly meetings to discuss major initiatives and issues that affect the business as a whole

Organizational Structure and Assignment of Authority and Responsibility

MERGE maintains an organizational chart, reflecting lines of reporting. A mapping of personnel to roles is available internally as well, allowing employees to be aware of employees filling multiple roles that would not be obvious from their title or position in the organizational hierarchy. This allows MERGE to move quickly as a small team, allowing employees to shift duties as needs arise. When an employee's role is changed permanently (either via a reporting change or a promotion), appropriate internal teams are notified.

MERGE has implemented the following control activities in this area:

- Organizational charts are in place to communicate key areas of authority and responsibility
- Organizational charts are communicated to employees and updated as needed

Human Resources Policies and Practices

<u>Hiring</u>

- New Employees go through a defined hiring process with a screening, technical interview, psychometric testing, final interviews, call with founders, and references checks before an offer is made. Interviewers and Human Resources (HR) is responsible for documenting every step in the interview questionnaire and via Bamboo HR

<u>Onboarding</u>

- All new hires have dedicated and structured training that includes HR policies and Information security training. Acknowledgements are signed after the training
- All new hires are required to review the employee experience wiki, which is the entity's employee handbook. Acknowledgments are signed upon completion
- An access sheet is provided to the new employee with individual logins they will need to create with secure passwords
- A biweekly check in is completed with HR to ensure an optimal experience

<u>Evaluations</u>

- All employees have weekly one on ones with their managers where they exchange feedback and talk through challenges
- All employees have quarterly conversations with their managers and an annual review. The quarterly conversations happen in Dec, Mar, and June. The annual review is in September. All conversations are documented in the employee's individual Soundtrack conversations

<u>Counseling</u>

- Employees are welcome to reach out to HR for any concerns or questions. They may also reach out to the company's EAP services associated with TriNet or Manulife

<u>Promotion</u>

- The promotion process is based on the employee's performance and practice of company values. This varies from role to role. Upon promotion, the employee may be granted additional access, and the role/title change is documented in Bamboo HR, TriNet, and the company's website

Compensation

- Compensation reviews happen annual either in April or October of every year depending on the employee's hire date at MERGE. Several factors may influence an employee's rate of pay. Some of these factors are the essential duties and responsibilities of the role, market data on pay practices of other employers in the area, internal equity among employees in the same roles, as well as individual and company performance

Disciplinary Action

- There is a defined disciplinary action policy at MERGE that includes verbal warnings, written warnings, and final warnings. It is the manager's responsibility to document all warnings in the employee's soundtrack and consult with HR as needed

Termination

- All employees being terminated whether voluntary or involuntary, need to go through a series of steps, from signing a release to completing an exit interview. All employee logins and accounts must be deleted once the employee is terminated

Risk Assessment Process

MERGE identifies and gathers risks to MERGE's products, customers, or reputation on a constant basis (encouraging all employees to report risks they discover). Executive Management formally reviews risks on a quarterly basis or when a severe risk is identified.

Risks are categorized by:

- Potential impact
- Chance of occurring,
- Criticality of impacted asset

Based on these categories, an overall score is assigned during the Risk Assessment. Based on this score, appropriate mitigation is considered. For each risk item, either the risk is accepted (deemed tolerable based on other factors or cost of mitigation), or an appropriate mitigation strategy is determined. The risk is either resolved via direct action, monitored, or transferred to a third-party to assume liability. All new and previously reviewed items are re-reviewed and potentially re-scored during each Risk Assessment.

Information and Communications Systems

Because the company is still small, MERGE holds monthly video meetings with all employees to give a summary of each department's current objectives and activities, and how well those activities are accomplishing the objectives. Any questions are solicited and welcomed from all employees.

In addition, Executive Management has a weekly meeting, and each department has a weekly team meeting. The manager of each department is responsible for informing the executive management of the department's results and any issues with potential solutions. Those solutions are discussed at the executive management level and then communicated back to each department.

Monitoring Controls

MERGE maintains a direct mapping of the policy document to monitored controls. These controls are assessed and reviewed quarterly to discover if any gaps have occurred between the written policy and actions that have been taken. The results of these controls are used to determine when additional monitoring or enforcement is needed so that policies are followed, as well as to determine when policies need revision.

Changes to the System in the Last 12 Months

No significant changes have occurred to the services provided to user entities in the 12 months preceding the end of the review period.

Incidents in the Last 12 Months

No significant incidents have occurred to the services provided to user entities in the 12 months preceding the end of the review period.

Criteria Not Applicable to the System

All Common / Security criteria were applicable to MERGE's Marketing Consulting and Jeto SaaS Services System.

Subservice Organizations

This report does not include the cloud hosting services provided by AWS or GCP at various facilities.

Subservice Description of Services

AWS and GCP provide the cloud hosting services utilized to deliver MERGE's Marketing Consulting and Jeto SaaS Services System.

Complementary Subservice Organization Controls

MERGE's services are designed with the assumption that certain controls will be implemented by subservice organizations. Such controls are called complementary subservice organization controls. It is not feasible for all of the trust services criteria related to MERGE's services to be solely achieved by MERGE control procedures. Accordingly, subservice organizations, in conjunction with the services, should establish their own internal controls or procedures to complement those of MERGE.

The following subservice organization controls should be implemented by AWS to provide additional assurance that the trust services criteria described within this report are met:

Subservice Organization - AWS		
Category	**Criteria**	**Control**
Common Criteria / Security	CC6.4	Physical access to data centers is approved by an authorized individual.
		Physical access is revoked within 24 hours of the employee or vendor record being deactivated.
		Physical access to data centers is reviewed on a quarterly basis by appropriate personnel.

Subservice Organization - AWS		
Category	**Criteria**	**Control**
		Physical access points to server locations are recorded by closed circuit television camera (CCTV). Images are retained for 90 days, unless limited by legal or contractual obligations.
		Physical access points to server locations are managed by electronic access control devices.

The following subservice organization controls should be implemented by GCP to provide additional assurance that the trust services criteria described within this report are met:

Subservice Organization - GCP		
Category	**Criteria**	**Control**
Common Criteria / Security	CC6.4	Data center server floors network rooms and security systems are physically isolated from public spaces and/or delivery areas.
		Access to sensitive data center zones requires approval form authorized personnel and is controlled via badge access readers, biometric identification mechanism, and/or physical locks.
		Data center perimeters are defined and secured via physical barriers.
		Access lists to high security areas in data centers are reviewed on a periodic basis and inappropriate access is removed in a timely manner.
		Visitors to data center facilities must gain approval from authorized personnel, have their identity verified at the perimeter, and remain with an escort for the duration of the visit.
		Security measures utilized in data centers are assessed annually and the results are reviewed by executive management.
		Data centers are continuously staffed and monitored by security personnel through the use of real time video surveillance and/or alerts generated by security systems.

MERGE management, along with the subservice organizations, define the scope and responsibility of the controls necessary to meet all the relevant trust services criteria through written contracts, such as service level agreements. In addition, MERGE performs monitoring of the subservice organization controls, including the following procedures:

- Reviewing and reconciling output reports
- Reviewing attestation reports over services provided by vendors and subservice organizations
- Monitoring external communications, such as customer complaints relevant to the services provided by the subservice organizations

COMPLEMENTARY USER ENTITY CONTROLS

MERGE's services are designed with the assumption that certain controls will be implemented by user entities. Such controls are called complementary user entity controls. It is not feasible for all of the Trust Services Criteria related to MERGE's services to be solely achieved by MERGE control procedures. Accordingly, user entities, in conjunction with the services, should establish their own internal controls or procedures to complement those of MERGE. The following complementary user entity controls should be implemented by user entities to provide additional assurance that the Trust Services Criteria described within this report are met. As these items represent only a part of the control considerations that might be pertinent at the user entities' locations, user entities' auditors should exercise judgment in selecting and reviewing these complementary user entity controls.

1. User entities are responsible for understanding and complying with their contractual obligations to MERGE.
2. User entities are responsible for notifying MERGE of changes made to technical or administrative contact information.
3. User entities are responsible for maintaining their own systems of record.
4. User entities are responsible for ensuring the supervision, management, and control of the use of MERGE services by their personnel.
5. User entities are responsible for developing their own disaster recovery and business continuity plans that address the inability to access or utilize MERGE services.
6. User entities are responsible for providing MERGE with a list of approvers for security and system configuration changes for data transmission.
7. User entities are responsible for immediately notifying MERGE of any actual or suspected information security breaches, including compromised user accounts, including those used for integrations and secure file transfers.

TRUST SERVICES CATEGORIES

In-Scope Trust Services Categories

Common Criteria (to the Security Category)
Security refers to the protection of: i. information during its collection or creation, use, processing, transmission, and storage and ii. systems that use electronic information to process, transmit or transfer, and store information to enable the entity to meet its objectives. Controls over security prevent or detect the breakdown and circumvention of segregation of duties, system failure, incorrect processing, theft or other unauthorized removal of information or system resources, misuse of software, and improper access to or use of, alteration, destruction, or disclosure of information.

Control Activities Specified by the Service Organization

The applicable trust services criteria, risks, and related control activities are included in Section 4 of this report to eliminate the redundancy that would result from listing them in this section. Although the applicable trust services criteria and related control activities are included in Section 4, they are, nevertheless, an integral part of MERGE's description of the system. Any applicable trust services criteria that are not addressed by control activities at MERGE are described within Section 4 and within the Subservice Organization and Criteria Not Applicable to the System sections above.

The description of the service auditor's tests of operating effectiveness and the results of those tests are also presented in Section 4. The description of the tests of operating effectiveness and the results of those tests are the responsibility of the service auditor and should be considered information provided by the service auditor.

SECTION 4

TRUST SERVICES CATEGORY, CRITERIA, RELATED CONTROLS, AND TESTS OF CONTROLS

Proprietary and Confidential

GUIDANCE REGARDING TRUST SERVICES CATEGORY, CRITERIA, RELATED CONTROLS, AND TESTS OF CONTROLS

A-LIGN ASSURANCE's examination of the controls of MERGE was limited to the Trust Services Criteria, related criteria and control activities specified by the management of MERGE and did not encompass all aspects of MERGE's operations or operations at user entities. Our examination was performed in accordance with American Institute of Certified Public Accountants (AICPA) AT-C 105 and AT-C 205.

Our examination of the control activities was performed using the following testing methods:

TEST	DESCRIPTION
Inquiry	The service auditor made inquiries of service organization personnel. Inquiries were made to obtain information and representations from the client to determine that the client's knowledge of the control and corroborate policy or procedure information.
Observation	The service auditor observed application of the control activities by client personnel.
Inspection	The service auditor inspected among other items, source documents, reports, system configurations to determine performance of the specified control activity and in some instances the timeliness of the performance of control activities.
Re-performance	The service auditor independently executed procedures or controls that were originally performed by the service organization as part of the entity's internal control.

In determining whether the report meets the criteria, the user auditor should perform the following procedures:

- Understand the aspects of the service organization's controls that may affect the service commitments and system requirements based on the applicable trust services criteria;
- Understand the infrastructure, software, procedures and data that are designed, implemented and operated by the service organization;
- Determine whether the criteria are relevant to the user entity's assertions; and
- Determine whether the service organization's controls are suitably designed to provide reasonable assurance that its service commitments and system were achieved based on the applicable trust services criteria.

CONTROL ACTIVITIES SPECIFIED BY THE SERVICE ORGANIZATION

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Control Environment				
CC1.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
CC1.1	COSO Principle 1: The entity demonstrates a commitment to integrity and ethical values.	Core values are communicated from executive management to personnel through policies, directives, guidelines, the code of conduct, and the employee handbook.	Inspected the employee handbook, the information security policies, and the entity's intranet to determine that core values were communicated from executive management to personnel through policies, directives, guidelines, the code of conduct, and the employee handbook.	No exceptions noted.
		An employee handbook and code of conduct are documented to communicate workforce conduct standards and enforcement procedures.	Inspected the employee handbook to determine that an employee handbook and code of conduct were documented to communicate workforce conduct standards and enforcement procedures.	No exceptions noted.
		Upon hire, personnel are required to acknowledge the employee handbook and code of conduct.	Inquired of the Director of Information Security regarding onboarding new hires to determine that upon hire, personnel were required to acknowledge the employee handbook and code of conduct.	No exceptions noted.
			Inspected the user on-boarding procedures to determine that upon hire, personnel were required to acknowledge the employee handbook and code of conduct.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Control Environment				
CC1.0	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
			Inspected the signed employee handbook and code of conduct completion tracking list for a sample of new hires to determine that upon hire, personnel were required to acknowledge the employee handbook and code of conduct.	No exceptions noted.
		Prior to employment, personnel are required to complete a background check.	Inspected the completed background check form for a sample of new hires to determine that prior to employment, personnel were required to complete a background check.	No exceptions noted.
		Personnel are required to acknowledge the employee handbook and code of conduct on an annual basis.	Inspected the signed employee handbook and code of conduct acknowledgement completion tracking list for a sample of current employees to determine that personnel were required to acknowledge the employee handbook and code of conduct on an annual basis.	No exceptions noted.
		Performance and conduct evaluations are performed for personnel on a quarterly basis.	Inquired of the Director of Information Security regarding performance evaluations to determine that performance and conduct evaluations were performed for personnel on a quarterly basis.	No exceptions noted.
			Inspected the performance evaluation procedure to determine that performance and conduct evaluations were performed for personnel on a quarterly basis.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Control Environment				
CC1.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
			Inspected the completed performance evaluation tracking spreadsheet for a sample of current employees to determine that performance and conduct evaluations were performed for personnel on a quarterly basis.	Testing of the control activity disclosed that a performance and conduct evaluation was not performed on a quarterly basis for nine out of 25 current employees sampled.
		Sanction policies, which include probation, suspension and termination, are in place for employee misconduct.	Inspected the disciplinary actions policies and procedures to determine that sanction policies, which include probation, suspension and termination, were in place for employee misconduct.	No exceptions noted.
		Employees, third parties, and customers are directed on how to report unethical behavior in a confidential manner.	Inspected the privacy policy, the entity's website and the entity's internal channel to determine that employees, third parties, and customers were directed on how to report unethical behavior in a confidential manner.	No exceptions noted.
		Upon hire, personnel are required to sign a confidentiality agreement.	Inspected the signed confidentiality agreement for a sample of new hires to determine that upon hire, personnel were required to sign a confidentiality agreement.	No exceptions noted.
CC1.2	COSO Principle 2: The board of directors demonstrates independence from management and exercises oversight of the development and performance of internal control.	Performance and conduct evaluations are performed for personnel on a quarterly basis.	Inquired of the Director of Information Security regarding performance evaluations to determine that performance and conduct evaluations were performed for personnel on a quarterly basis.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Control Environment				
CC1.0	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
			Inspected the performance evaluation procedure to determine that performance and conduct evaluations were performed for personnel on a quarterly basis.	No exceptions noted.
			Inspected the completed performance evaluation tracking spreadsheet for a sample of current employees to determine that performance and conduct evaluations were performed for personnel on a quarterly basis.	Testing of the control activity disclosed that a performance and conduct evaluation was not performed on a quarterly basis for nine out of 25 current employees sampled.
		Executive management roles and responsibilities are documented and reviewed annually.	Inspected the executive management job descriptions and the career framework PowerPoint deck to determine that executive management roles and responsibilities were documented and reviewed annually.	No exceptions noted.
		Executive management defines and documents the skills and expertise needed among its members.	Inspected the executive management job descriptions and the career framework PowerPoint deck to determine that executive management defined and documented the skills and expertise needed among its members.	No exceptions noted.
		Executive management maintains independence from those that operate the key controls implemented within the environment.	Inspected the organizational chart and the completed internal controls matrix to determine that executive management-maintained independence from those that operate the key controls implemented within the environment.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Control Environment				
CC1.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		Executive management meets quarterly with operational management to assess the effectiveness and performance of internal controls implemented within the environment.	Inspected the management meeting notes for a sample of quarters to determine that executive management met quarterly with operational management to assess the effectiveness and performance of internal controls implemented within the environment.	No exceptions noted.
		Operational management assigns responsibility for and monitors the effectiveness and performance of internal controls implemented within the environment.	Inspected the completed risk assessment and the information security roles and responsibilities to determine that operational management assigned responsibility for and monitored the effectiveness and performance of internal controls implemented within the environment.	No exceptions noted.
		Responsible parties are defined and assigned to coordinate and monitor compliance and audit activities.	Inspected the organizational chart, the completed risk assessment and the information security roles and responsibilities to determine that responsible parties were defined and assigned to coordinate and monitor compliance and audit activities.	No exceptions noted.
CC1.3	COSO Principle 3: Management establishes, with board oversight, structures, reporting lines, and appropriate authorities and responsibilities in the pursuit of objectives.	Executive management maintains independence from those that operate the key controls implemented within the environment.	Inspected the organizational chart and the completed internal controls matrix to determine that executive management-maintained independence from those that operate the key controls implemented within the environment.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Control Environment				
CC1.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		A documented organizational chart is in place that defines organizational structures, lines of reporting, and areas of authority.	Inspected the organizational chart to determine that a documented organizational chart was in place that defined organizational structures, lines of reporting, and areas of authority.	No exceptions noted.
		Executive management reviews the organizational chart annually and makes updates to the organizational structure and lines of reporting, if necessary.	Inspected the revision history of the organizational chart to determine that executive management reviewed the organizational chart annually and made updates to the organizational structure and lines of reporting, if necessary.	No exceptions noted.
		Roles and responsibilities are defined in written job descriptions and communicated to personnel through the entity's intranet.	Inspected the job description for a sample of job roles and the entity's intranet to determine that roles and responsibilities were defined in written job descriptions and communicated to personnel through the entity's intranet.	No exceptions noted.
		Executive management reviews job descriptions annually and makes updates, if necessary.	Inspected the job descriptions and career framework PowerPoint deck for a sample of job roles to determine that executive management reviewed job descriptions annually and made updates, if necessary.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Control Environment				
CC1.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		Executive management has established proper segregations of duties for key job functions and roles within the organization.	Inspected the organizational chart, the completed internal controls matrix, and the job descriptions for a sample of job roles to determine that executive management established proper segregations of duties for key job functions and roles within the organization.	No exceptions noted.
		A vendor risk assessment is performed on an annual basis which includes reviewing the activities performed by critical third parties.	Inspected the vendor risk assessment policies and procedures and the completed vendor risk assessment to determine that a vendor risk assessment was performed on an annual basis which included reviewing the activities performed by critical third parties.	No exceptions noted.
		Management obtains and reviews attestation reports and vendor questionnaires of vendors and third parties to evaluate the effectiveness of controls within the vendor or third party's environment.	Inspected the completed third-party attestation report for a sample of third parties that the entity has a relationship with to determine that management obtained and reviewed attestation reports of vendors and third parties to evaluate the effectiveness of controls within the vendor or third party's environment.	No exceptions noted.
CC1.4	COSO Principle 4: The entity demonstrates a commitment to attract, develop, and retain competent individuals in alignment with objectives.	Prior to employment, personnel are required to complete a background check.	Inspected the completed background check form for a sample of new hires to determine that prior to employment, personnel were required to complete a background check.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Control Environment				
CC1.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		Performance and conduct evaluations are performed for personnel on a quarterly basis.	Inquired of the Director of Information Security regarding performance evaluations to determine that performance and conduct evaluations were performed for personnel on a quarterly basis.	No exceptions noted.
			Inspected the performance evaluation procedure to determine that performance and conduct evaluations were performed for personnel on a quarterly basis.	No exceptions noted.
			Inspected the completed performance evaluation tracking spreadsheet for a sample of current employees to determine that performance and conduct evaluations were performed for personnel on a quarterly basis.	Testing of the control activity disclosed that a performance and conduct evaluation was not performed on a quarterly basis for nine out of 25 current employees sampled.
		A vendor risk assessment is performed on an annual basis which includes reviewing the activities performed by critical third parties.	Inspected the vendor risk assessment policies and procedures and the completed vendor risk assessment to determine that a vendor risk assessment was performed on an annual basis which included reviewing the activities performed by critical third parties.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Control Environment				
CC1.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		Policies and procedures are in place that outline the performance evaluation process as well as the competency and training requirements for personnel.	Inspected the employee handbook and procedures and the training policies and procedures to determine that policies and procedures were in place that outlined the performance evaluation process as well as the competency and training requirements for personnel.	No exceptions noted.
		The entity evaluates the competencies and experience of candidates prior to hiring, and of personnel transferring job roles or responsibilities.	Inquired of the Director of Information Security regarding evaluation prior to hire to determine that the entity evaluated the competencies and experience of candidates prior to hiring, and of personnel transferring job roles or responsibilities.	No exceptions noted.
			Inspected the employee handbook to determine that the entity evaluated the competencies and experience of candidates prior to hiring, and of personnel transferring job roles or responsibilities.	No exceptions noted.
			Inspected the interview notes and supporting communications for a sample of new hires to determine that the entity evaluated the competencies and experience of candidates prior to hiring, and of personnel transferring job roles or responsibilities.	Testing of the control activity disclosed that interview notes were not retained for one of the 15 new hires sampled. Subsequent testing disclosed that the one user did not hold a critical role and was confirmed to not be a user with privileged access to the production environment.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Control Environment				
CC1.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		The entity has a recruiting department that is responsible for attracting individuals with competencies and experience that align with the entity's goals and objectives.	Inspected the talent acquisition interview guides, onboarding and offboarding procedures, and the background screening procedure to determine that the entity had a recruiting department that was responsible for attracting individuals with competencies and experience that aligned with the entity's goals and objectives.	No exceptions noted.
		Employees are required to attend continued training annually that relates to their job role and responsibilities.	Inquired of the Director of Information Security regarding security awareness training to determine that employees were required to attend continued training annually that relates to their job roles and responsibilities.	No exceptions noted.
			Inspected the training policies and procedures to determine that employees were required to attend continued training annually that relates to their job role and responsibilities.	No exceptions noted.
			Inspected the training completion confirmation for a sample of current employees to determine that employees were required to attend continued training annually that relates to their job role and responsibilities.	No exceptions noted
		Executive management uses an outside vendor to assist with its continued training of employees.	Inspected the third-party invoice to determine that executive management used an outside vendor to assist with its continued training of employees.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Control Environment				
CC1.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		The entity has implemented a mentor program to develop its personnel.	Inspected the mentor program overview to determine that the entity created a mentor program for its employees.	No exceptions noted.
		Executive management tracks and monitors compliance with continued professional education (CPE) training requirements.	Inspected the employee trainings log to determine that executive management tracked and monitored compliance with CPE training requirements.	No exceptions noted.
		The entity assesses training needs on an annual basis.	Inspected the yearly training review and scheduled training plan to determine that the entity assessed the training needs on an annual basis.	No exceptions noted.
		Management obtains and reviews attestation reports and vendor questionnaires of vendors and third parties to evaluate the effectiveness of controls within the vendor or third party's environment.	Inspected the completed third-party attestation report for a sample of third parties that the entity has a relationship with to determine that management obtained and reviewed attestation reports of vendors and third parties to evaluate the effectiveness of controls within the vendor or third party's environment.	No exceptions noted.
CC1.5	COSO Principle 5: The entity holds individuals accountable for their internal control responsibilities in the pursuit of objectives.	Upon hire, personnel are required to acknowledge the employee handbook and code of conduct.	Inquired of the Director of Information Security regarding onboarding new hires to determine that upon hire, personnel were required to acknowledge the employee handbook and code of conduct.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Control Environment				
CC1.0	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
			Inspected the user on-boarding procedures to determine that upon hire, personnel were required to acknowledge the employee handbook and code of conduct.	No exceptions noted.
			Inspected the signed employee handbook and code of conduct completion tracking list for a sample of new hires to determine that upon hire, personnel were required to acknowledge the employee handbook and code of conduct.	No exceptions noted.
		Personnel are required to acknowledge the employee handbook and code of conduct on an annual basis.	Inspected the signed employee handbook and code of conduct acknowledgement completion tracking list for a sample of current employees to determine that personnel were required to acknowledge the employee handbook and code of conduct on an annual basis.	No exceptions noted.
		Performance and conduct evaluations are performed for personnel on a quarterly basis.	Inquired of the Director of Information Security regarding performance evaluations to determine that performance and conduct evaluations were performed for personnel on a quarterly basis.	No exceptions noted.
			Inspected the performance evaluation procedure to determine that performance and conduct evaluations were performed for personnel on a quarterly basis.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Control Environment				
CC1.0	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
			Inspected the completed performance evaluation tracking spreadsheet for a sample of current employees to determine that performance and conduct evaluations were performed for personnel on a quarterly basis.	Testing of the control activity disclosed that a performance and conduct evaluation was not performed on a quarterly basis for nine out of 25 current employees sampled.
		Sanction policies, which include probation, suspension and termination, are in place for employee misconduct.	Inspected the disciplinary actions policies and procedures to determine that sanction policies, which include probation, suspension and termination, were in place for employee misconduct.	No exceptions noted.
		A documented organizational chart is in place that defines organizational structures, lines of reporting, and areas of authority.	Inspected the organizational chart to determine that a documented organizational chart was in place that defined organizational structures, lines of reporting, and areas of authority.	No exceptions noted.
		Roles and responsibilities are defined in written job descriptions and communicated to personnel through the entity's intranet.	Inspected the job description for a sample of job roles and the entity's intranet to determine that roles and responsibilities were defined in written job descriptions and communicated to personnel through the entity's intranet.	No exceptions noted.
		Executive management reviews job descriptions annually and makes updates, if necessary.	Inspected the job descriptions and career framework PowerPoint deck for a sample of job roles to determine that executive management reviewed job descriptions annually and made updates, if necessary.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Control Environment				
CC1.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		Policies and procedures are in place that outline the performance evaluation process as well as the competency and training requirements for personnel.	Inspected the employee handbook and procedures and the training policies and procedures to determine that policies and procedures were in place that outlined the performance evaluation process as well as the competency and training requirements for personnel.	No exceptions noted.
		Executive management reviews the job requirements and responsibilities documented within job descriptions annually and makes updates, if necessary.	Inspected the career framework PowerPoint deck and job descriptions including the revision date for a sample of job roles to determine that executive management reviewed the job requirements and responsibilities documented within job descriptions annually and made updates, if necessary.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Information and Communication				
CC2.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
CC2.1	COSO Principle 13: The entity obtains or generates and uses relevant, quality information to support the functioning of internal control.	Organizational and information security policies and procedures are documented and made available to personnel through the entity's intranet.	Inspected the information security policy and the entity's intranet to determine that organizational and information security policies and procedures were documented and made available to its personnel through the entity's intranet.	No exceptions noted.
		Edit checks are in place to prevent incomplete or incorrect data from being entered into the system.	Inquired of the Director of Information Security regarding edit checks to determine that edit checks were in place to prevent incomplete or incorrect data from being entered into the system.	No exceptions noted.
			Inspected the edit check configurations to determine that edits checks were in place to prevent incomplete or incorrect data from being entered into the system.	No exceptions noted.
		Data flow diagrams are documented and maintained by management to identify the relevant internal and external information sources of the system.	Inspected the data flow diagrams to determine that data flow diagrams were documented and maintained by management to identify the relevant internal and external information sources of the system.	No exceptions noted.
		Data entered into the system, processed by the system and output from the system is protected from unauthorized access.	Inspected the encryption configurations for data in transit and digital certificates and VPN authentication configurations to determine that data entered into the system, processed by the system and output from the system was protected from unauthorized access.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Information and Communication				
CC2.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		Data is only retained for as long as required to perform the required system functionality, service or use.	Inspected the data retention policies and procedures to determine that data was retained for only as long as required to perform the required system functionality, service or use.	No exceptions noted.
CC2.2	COSO Principle 14: The entity internally communicates information, including objectives and responsibilities for internal control, necessary to support the functioning of internal control.	Core values are communicated from executive management to personnel through policies, directives, guidelines, the code of conduct, and the employee handbook.	Inspected the employee handbook, the information security policies, and the entity's intranet to determine that core values were communicated from executive management to personnel through policies, directives, guidelines, the code of conduct, and the employee handbook.	No exceptions noted.
		Upon hire, personnel are required to acknowledge the employee handbook and code of conduct.	Inquired of the Director of Information Security regarding onboarding new hires to determine that upon hire, personnel were required to acknowledge the employee handbook and code of conduct.	No exceptions noted.
			Inspected the user on-boarding procedures to determine that upon hire, personnel were required to acknowledge the employee handbook and code of conduct.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Information and Communication				
CC2.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
			Inspected the signed employee handbook and code of conduct completion tracking list for a sample of new hires to determine that upon hire, personnel were required to acknowledge the employee handbook and code of conduct.	No exceptions noted.
		Personnel are required to acknowledge the employee handbook and code of conduct on an annual basis.	Inspected the signed employee handbook and code of conduct acknowledgement completion tracking list for a sample of current employees to determine that personnel were required to acknowledge the employee handbook and code of conduct on an annual basis.	No exceptions noted.
		Employees, third parties, and customers are directed on how to report unethical behavior in a confidential manner.	Inspected the privacy policy, the entity’s website and the entity’s internal channel to determine that employees, third parties, and customers were directed on how to report unethical behavior in a confidential manner.	No exceptions noted.
		Roles and responsibilities are defined in written job descriptions and communicated to personnel through the entity's intranet.	Inspected the job description for a sample of job roles and the entity's intranet to determine that roles and responsibilities were defined in written job descriptions and communicated to personnel through the entity's intranet.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Information and Communication				
CC2.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		Employees are required to attend continued training annually that relates to their job role and responsibilities.	Inquired of the Director of Information Security regarding security awareness training to determine that employees were required to attend continued training annually that relates to their job roles and responsibilities.	No exceptions noted.
			Inspected the training policies and procedures to determine that employees were required to attend continued training annually that relates to their job role and responsibilities.	No exceptions noted.
			Inspected the training completion confirmation for a sample of current employees to determine that employees were required to attend continued training annually that relates to their job role and responsibilities.	No exceptions noted.
		Organizational and information security policies and procedures are documented and made available to personnel through the entity's intranet.	Inspected the information security policy and the entity’s intranet to determine that organizational and information security policies and procedures were documented and made available to its personnel through the entity’s intranet.	No exceptions noted.
		The entity's policies and procedures, code of conduct and employee handbook are made available to personnel through the entity's intranet.	Inspected the entity's intranet to determine that the entity's policies and procedures, code of conduct and employee handbook were made available to personnel through the entity's intranet.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Information and Communication				
CC2.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		Upon hire, personnel are required to complete information security awareness training.	Inspected the information security awareness training completion tracker for a sample of new hires to determine that upon hire, personnel were required to complete information security awareness training.	No exceptions noted.
		Current employees are required to read and acknowledge the information security policies and procedures and complete information security and awareness training on an annual basis.	Inquired of the Director of Information Security regarding security awareness training to determine that current employees were required to read and acknowledge the information security policies and procedures and complete information security and awareness training on an annual basis.	No exceptions noted.
			Inspected the training policies and procedures to determine that current employees were required to read and acknowledge the information security policies and procedures and complete information security and awareness training on an annual basis.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Information and Communication				
CC2.0	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
			Inspected the information security and awareness training completion confirmation for a sample of current employees to determine that current employees were required to read and acknowledge the information security policies and procedures and complete information security and awareness training on an annual basis.	Testing of the control activity disclosed that security awareness training was not completed timely for four out of 25 current employees sampled.
		Executive management meets quarterly with operational management to discuss the entity's objectives as well as roles and responsibilities.	Inspected the management meeting minutes for a sample of quarters to determine that executive management met quarterly with operational management to discuss the entity's objectives as well as roles and responsibilities.	No exceptions noted.
		Changes to job roles and responsibilities are communicated to personnel through the entity's intranet.	Inspected the entity’s intranet to determine that changes to job roles and responsibilities were communicated to personnel through the entity's intranet.	No exceptions noted.
		Documented escalation procedures for reporting failures incidents, concerns and other complaints are in place and made available to employees through the entity's intranet.	Inspected the incident management policy and the entity's intranet to determine that documented escalation procedures for reporting failures incidents, concerns and other complaints were in place and made available to employees through the entity's intranet.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Information and Communication				
CC2.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		The entity's objectives, including changes made to the objectives, are communicated to its personnel through the entity's intranet.	Inspected the entity's intranet to determine that the entity's objectives, including changes made to the objectives, were communicated to its personnel through the entity's intranet.	No exceptions noted.
		Responsible parties are defined and assigned to coordinate and monitor compliance and audit activities.	Inspected the organizational chart, the completed risk assessment and the information security roles and responsibilities to determine that responsible parties were defined and assigned to coordinate and monitor compliance and audit activities.	No exceptions noted.
		Documented incident response and escalation procedures for reporting security incidents are in place to guide users in identifying, reporting and mitigating failures, incidents, concerns, and other complaints.	Inspected the incident response policy to determine that documented incident response and escalation procedures for reporting security incidents were in place to guide users in identifying, reporting and mitigating failures, incidents, concerns, and other complaints.	No exceptions noted.
CC2.3	COSO Principle 15: The entity communicates with external parties regarding matters affecting the functioning of internal control.	Employees, third parties, and customers are directed on how to report unethical behavior in a confidential manner.	Inspected the privacy policy, the entity’s website and the entity’s internal channel to determine that employees, third parties, and customers were directed on how to report unethical behavior in a confidential manner.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Information and Communication				
CC2.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		Documented escalation procedures for reporting failures incidents, concerns and other complaints are in place and made available to employees through the entity's intranet.	Inspected the incident management policy and the entity's intranet to determine that documented escalation procedures for reporting failures incidents, concerns and other complaints were in place and made available to employees through the entity's intranet.	No exceptions noted.
		The entity's third-party agreement delineates the boundaries of the system and describes relevant system components.	Inspected the master third-party agreement template and third-party agreement for a sample of third parties to determine that the entity's third-party agreement delineated the boundaries of the system and described relevant system components.	No exceptions noted.
		The entity's third-party agreement communicates the system commitments and requirements of third parties.	Inspected the third-party master agreement template to determine that the entity's third-party agreement communicated the system commitments and requirements of third parties.	No exceptions noted.
		The entity's third-party agreement outlines and communicates the terms, conditions and responsibilities of third parties.	Inspected the master third-party agreement template and the executed third-party agreement for a sample of third parties to determine that the entity's third-party agreement outlined and communicated the terms, conditions and responsibilities of third parties.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Information and Communication				
CC2.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		Customer commitments, requirements and responsibilities are outlined and communicated through service agreements.	Inspected the executed customer agreement for a sample of customers to determine that customer commitments, requirements and responsibilities were outlined and communicated through service agreements.	No exceptions noted.
		Changes to commitments, requirements and responsibilities are communicated to third parties, external users, and customers via website notices.	Inspected the entity's release note articles to determine that changes to commitments, requirements and responsibilities were communicated to third parties, external users and customers via website notices.	No exceptions noted.
		Documented incident response and escalation procedures for reporting security incidents are in place to guide users in identifying, reporting and mitigating failures, incidents, concerns, and other complaints.	Inspected the incident response policy to determine that documented incident response and escalation procedures for reporting security incidents were in place to guide users in identifying, reporting and mitigating failures, incidents, concerns, and other complaints.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Risk Assessment				
CC3.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
CC3.1	COSO Principle 6: The entity specifies objectives with sufficient clarity to enable the identification and assessment of risks relating to objectives.	Executive management meets quarterly with operational management to assess the effectiveness and performance of internal controls implemented within the environment.	Inspected the management meeting notes for a sample of quarters to determine that executive management met quarterly with operational management to assess the effectiveness and performance of internal controls implemented within the environment.	No exceptions noted.
		A documented organizational chart is in place that defines organizational structures, lines of reporting, and areas of authority.	Inspected the organizational chart to determine that a documented organizational chart was in place that defined organizational structures, lines of reporting, and areas of authority.	No exceptions noted.
		Organizational and information security policies and procedures are documented and made available to personnel through the entity's intranet.	Inspected the information security policy and the entity's intranet to determine that organizational and information security policies and procedures were documented and made available to its personnel through the entity's intranet.	No exceptions noted.
		The entity establishes organizational strategies and objectives that are used to determine entity structure and performance metrics.	Inspected the organizational chart, employee performance evaluation policies and procedures and the entity's documented objectives and strategies to determine that the entity established organizational strategies and objectives that were used to determine entity structure and performance metrics.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Risk Assessment				
CC3.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		Executive management has documented objectives that are specific, measurable, attainable, relevant and time-bound (SMART).	Inspected the entity's documented objectives and strategies to determine that executive management had documented objectives that were SMART.	No exceptions noted.
		Executive management identifies and assesses risks that could prevent the entity's objectives from being achieved.	Inspected the risk assessment and management policies and procedures and completed risk assessment to determine that executive management identified and assessed risks that could prevent the entity's objectives from being achieved.	No exceptions noted.
		Executive management has established key performance indicators for operational and internal controls effectiveness, including the acceptable level of control operation and failure.	Inspected the MERGE InfoSec metrics to determine that executive management established key performance indicators for operational and internal controls effectiveness, including the acceptable level of control operation and failure.	No exceptions noted.
		Responsible parties are defined and assigned to coordinate and monitor compliance and audit activities.	Inspected the organizational chart, the completed risk assessment and the information security roles and responsibilities to determine that responsible parties were defined and assigned to coordinate and monitor compliance and audit activities.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Risk Assessment				
CC3.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		Executive management reviews operational and resourcing reports to evaluate performance and resourcing at least annually.	Inspected the MERGE InfoSec metrics, the annual budget plan and the executive planning meeting agenda to determine that executive management reviewed operational and resourcing reports to evaluate performance and resourcing at least annually.	No exceptions noted.
		Key performance indicators of both the business performance and employee performance are developed in alignment with entity objectives and strategies.	Inspected the employee performance policies and procedures and the entity's metrics to determine that key performance indicators of both the business performance and employee performance were developed in alignment with entity objectives and strategies.	No exceptions noted.
		Business plans and budgets align with the entity's strategies and objectives.	Inspected the annual strategic plan and the annual budget plan to determine that business plans and budgets aligned with the entity's strategies and objectives.	No exceptions noted.
		Entity strategies, objectives and budgets are assessed on an annual basis.	Inspected the annual strategic plan, the annual budget plan and the management meeting agenda to determine that entity strategies, objectives and budgets were assessed on an annual basis.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Risk Assessment				
CC3.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		Management has defined a formal risk assessment process that specifies the process for identifying internal and external threats and vulnerabilities, evaluating and addressing risks and defining specified risk tolerances.	Inspected the risk management policy to determine that management defined a formal risk assessment process that specified the process for identifying internal and external threats and vulnerabilities, evaluating and addressing risks and defining specified risk tolerances.	No exceptions noted.
		A formal risk assessment is performed on at least an annual basis to identify internal and external threats and vulnerabilities that could impair system commitments and requirements.	Inspected the completed risk assessment to determine that a formal risk assessment was performed on an annual basis to identify internal and external threats and vulnerabilities that could impair system commitments and requirements.	No exceptions noted.
		Management develops risk mitigation strategies, including the implementation of controls, to address risks identified during the risk assessment process.	Inspected the risk management policy to determine that management developed risk mitigation strategies, including the implementation of controls, to address risks identified during the risk assessment process.	No exceptions noted.
CC3.2	COSO Principle 7: The entity identifies risks to the achievement of its objectives across the entity and analyzes risks as a basis for determining how the risks should be managed.	A vendor risk assessment is performed on an annual basis which includes reviewing the activities performed by critical third parties.	Inspected the vendor risk assessment policies and procedures and the completed vendor risk assessment to determine that a vendor risk assessment was performed on an annual basis which included reviewing the activities performed by critical third parties.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Risk Assessment				
CC3.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		Documented policies and procedures are in place to guide personnel when performing a risk assessment.	Inspected the risk management policy to determine that documented policies and procedures were in place to guide personnel when performing a risk assessment.	No exceptions noted.
		Management has defined a formal risk assessment process that specifies the process for identifying internal and external threats and vulnerabilities, evaluating and addressing risks and defining specified risk tolerances.	Inspected the risk management policy to determine that management defined a formal risk assessment process that specified the process for identifying internal and external threats and vulnerabilities, evaluating and addressing risks and defining specified risk tolerances.	No exceptions noted.
		A formal risk assessment is performed on at least an annual basis to identify internal and external threats and vulnerabilities that could impair system commitments and requirements.	Inspected the completed risk assessment to determine that a formal risk assessment was performed on an annual basis to identify internal and external threats and vulnerabilities that could impair system commitments and requirements.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Risk Assessment				
CC3.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		The entity's risk assessment process includes: • Identifying the relevant information assets that are critical to business operations • Prioritizing the criticality of those relevant information assets • Identifying and assessing the impact of the threats to those information assets • Identifying and assessing the impact of the vulnerabilities associated with the identified threats • Assessing the likelihood of identified threats and vulnerabilities • Determining the risks associated with the information assets • Addressing the associated risks for each identified vulnerability	Inspected the risk assessment and management policies and procedures and completed risk assessment to determine that the entity's risk assessment process included: • Identifying the relevant information assets that were critical to business operations • Prioritizing the criticality of those relevant information assets • Identifying and assessing the impact of the threats to those information assets • Identifying and assessing the impact of the vulnerabilities associated with the identified threats • Assessing the likelihood of identified threats and vulnerabilities • Determining the risks associated with the information assets • Addressing the associated risks for each identified vulnerability	No exceptions noted.
		Identified risks are rated using a risk evaluation process and ratings are approved by management.	Inspected the risk management policy to determine that identified risks were rated using a risk evaluation process and ratings were approved by management.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Risk Assessment				
CC3.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		Risks identified as a part of the risk assessment process are addressed using one of the following strategies: • Avoid the risk • Mitigate the risk • Transfer the risk	Inspected the risk assessment and management policies and procedures and completed risk assessment to determine that risks identified as a part of the risk assessment process were addressed using one of the following strategies: • Avoid the risk • Mitigate the risk • Transfer the risk	No exceptions noted.
		Management develops risk mitigation strategies, including the implementation of controls, to address risks identified during the risk assessment process.	Inspected the risk management policy to determine that management developed risk mitigation strategies, including the implementation of controls, to address risks identified during the risk assessment process.	No exceptions noted.
		For gaps and vulnerabilities identified from the risk assessment, remediation efforts, including the implementation of controls, are assigned to process owners based on roles and responsibilities.	Inspected the risk management policy and the completed risk assessment to determine that for gaps and vulnerabilities identified from the risk assessment, remediation efforts, including the implementation of controls, were assigned to process owners based on roles and responsibilities.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Risk Assessment				
CC3.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		The annual comprehensive risk assessment results are reviewed and approved by appropriate levels of management.	Inspected the risk assessment and management policies and procedures and the completed risk assessment to determine that the annual comprehensive risk assessment results were reviewed and approved by appropriate levels of management.	No exceptions noted.
		Management obtains and reviews attestation reports and vendor questionnaires of vendors and third parties to evaluate the effectiveness of controls within the vendor or third party's environment.	Inspected the completed third-party attestation report for a sample of third parties that the entity has a relationship with to determine that management obtained and reviewed attestation reports of vendors and third parties to evaluate the effectiveness of controls within the vendor or third party's environment.	No exceptions noted.
CC3.3	COSO Principle 8: The entity considers the potential for fraud in assessing risks to the achievement of objectives.	Management has defined a formal risk assessment process that specifies the process for identifying internal and external threats and vulnerabilities, evaluating and addressing risks and defining specified risk tolerances.	Inspected the risk management policy to determine that management defined a formal risk assessment process that specified the process for identifying internal and external threats and vulnerabilities, evaluating and addressing risks and defining specified risk tolerances.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Risk Assessment				
CC3.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		A formal risk assessment is performed on at least an annual basis to identify internal and external threats and vulnerabilities that could impair system commitments and requirements.	Inspected the completed risk assessment to determine that a formal risk assessment was performed on an annual basis to identify internal and external threats and vulnerabilities that could impair system commitments and requirements.	No exceptions noted.
		On an annual basis, management identifies and assesses the types of fraud that could impact their business and operations.	Inspected the completed risk assessment to determine that, on an annual basis, management identified and assessed the types of fraud that could impact their business and operations.	No exceptions noted.
		As part of management's assessment of fraud risks, management considers key fraud factors such as incentives, pressures, opportunity for unauthorized access or use of data, and employee morale and attitude.	Inspected the completed risk assessment to determine that as part of management's assessment of fraud risks, management considered key fraud factors such as incentives, pressures, opportunity for unauthorized access or use of data, and employee morale and attitude.	No exceptions noted.
CC3.4	COSO Principle 9: The entity identifies and assesses changes that could significantly impact the system of internal control.	Executive management meets quarterly with operational management to assess the effectiveness and performance of internal controls implemented within the environment.	Inspected the management meeting notes for a sample of quarters to determine that executive management met quarterly with operational management to assess the effectiveness and performance of internal controls implemented within the environment.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Risk Assessment				
CC3.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		A vendor risk assessment is performed on an annual basis which includes reviewing the activities performed by critical third parties.	Inspected the vendor risk assessment policies and procedures and the completed vendor risk assessment to determine that a vendor risk assessment was performed on an annual basis which included reviewing the activities performed by critical third parties.	No exceptions noted.
		Changes to the business structure and operations are considered and evaluated as part of the annual comprehensive risk assessment.	Inspected the risk assessment and management policies and procedures and the completed risk assessment to determine that changes to the business structure and operations were considered and evaluated as part of the annual comprehensive risk assessment.	No exceptions noted.
		Changes in key management and personnel are considered and evaluated as part of the annual comprehensive risk assessment.	Inspected the risk assessment and management policies and procedures and the completed risk assessment to determine that changes in key management and personnel were considered and evaluated as part of the annual comprehensive risk assessment.	No exceptions noted.
		Changes to the entity's systems, applications, technologies, and tools are considered and evaluated as part of the annual comprehensive risk assessment.	Inspected the risk assessment and management policies and procedures and the completed risk assessment to determine that changes to the entity's systems, applications, technologies, and tools were considered and evaluated as part of the annual comprehensive risk assessment.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Risk Assessment				
CC3.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		Management obtains and reviews attestation reports and vendor questionnaires of vendors and third parties to evaluate the effectiveness of controls within the vendor or third party's environment.	Inspected the completed third-party attestation report for a sample of third parties that the entity has a relationship with to determine that management obtained and reviewed attestation reports of vendors and third parties to evaluate the effectiveness of controls within the vendor or third party's environment.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Monitoring Activities				
CC4.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
CC4.1	COSO Principle 16: The entity selects, develops, and performs ongoing and/or separate evaluations to ascertain whether the components of internal control are present and functioning.	Performance and conduct evaluations are performed for personnel on a quarterly basis.	Inquired of the Director of Information Security regarding performance evaluations to determine that performance and conduct evaluations were performed for personnel on a quarterly basis.	No exceptions noted.
			Inspected the performance evaluation procedure to determine that performance and conduct evaluations were performed for personnel on a quarterly basis.	No exceptions noted.
			Inspected the completed performance evaluation tracking spreadsheet for a sample of current employees to determine that performance and conduct evaluations were performed for personnel on a quarterly basis.	Testing of the control activity disclosed that a performance and conduct evaluation was not performed on a quarterly basis for nine out of 25 current employees sampled.
		Executive management meets quarterly with operational management to assess the effectiveness and performance of internal controls implemented within the environment.	Inspected the management meeting notes for a sample of quarters to determine that executive management met quarterly with operational management to assess the effectiveness and performance of internal controls implemented within the environment.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Monitoring Activities				
CC4.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		A vendor risk assessment is performed on an annual basis which includes reviewing the activities performed by critical third parties.	Inspected the vendor risk assessment policies and procedures and the completed vendor risk assessment to determine that a vendor risk assessment was performed on an annual basis which included reviewing the activities performed by critical third parties.	No exceptions noted.
		Organizational and information security policies and procedures are documented and made available to personnel through the entity's intranet.	Inspected the information security policy and the entity's intranet to determine that organizational and information security policies and procedures were documented and made available to its personnel through the entity's intranet.	No exceptions noted.
		Responsible parties are defined and assigned to coordinate and monitor compliance and audit activities.	Inspected the organizational chart, the completed risk assessment and the information security roles and responsibilities to determine that responsible parties were defined and assigned to coordinate and monitor compliance and audit activities.	No exceptions noted.
		A formal risk assessment is performed on at least an annual basis to identify internal and external threats and vulnerabilities that could impair system commitments and requirements.	Inspected the completed risk assessment to determine that a formal risk assessment was performed on an annual basis to identify internal and external threats and vulnerabilities that could impair system commitments and requirements.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Monitoring Activities				
CC4.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		Monitoring software is used to identify and evaluate ongoing system performance, capacity, security threats, changing resource utilization needs and unusual system activity.	Inspected the monitoring tool configurations, the centralized antivirus software dashboard console and the firewall settings to determine that monitoring software was used to identify and evaluate ongoing system performance, capacity, security threats, changing resource utilization needs and unusual system activity.	No exceptions noted.
		On a quarterly basis, management reviews the controls implemented within the environment for operational effectiveness and identifies potential control gaps and weaknesses.	Inspected the change management board meeting minutes for a sample of quarters to determine that on a quarterly basis, management reviewed the controls implemented within the environment for operational effectiveness and identified potential control gaps and weaknesses.	No exceptions noted.
		Backup restoration tests are performed on a semi-annual basis.	Inspected the completed backup restoration test to determine backup restoration tests were performed on a semi-annual basis.	No exceptions noted.
		Vulnerability scans are performed daily on the environment to identify control gaps and vulnerabilities.	Inspected the completed vulnerability scan results for a sample of days to determine that vulnerability scans were performed daily on the environment to identify control gaps and vulnerabilities.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Monitoring Activities				
CC4.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		A third party performs a penetration testing annually to identify and exploit vulnerabilities identified within the environment.	Inspected the completed penetration test results to determine that a third party performed a penetration testing annually to identify and exploit vulnerabilities identified within the environment.	No exceptions noted.
		Management obtains and reviews attestation reports and vendor questionnaires of vendors and third parties to evaluate the effectiveness of controls within the vendor or third party's environment.	Inspected the completed third-party attestation report for a sample of third parties that the entity has a relationship with to determine that management obtained and reviewed attestation reports of vendors and third parties to evaluate the effectiveness of controls within the vendor or third party's environment.	No exceptions noted.
		A user access review is performed on a semi-annual basis to validate the logical access to systems is appropriate for all personnel.	Inquired of the Director of Information Security regarding user access reviews to determine that logical access reviews were performed on a semi-annual basis.	No exceptions noted.
			Inspected the completed VPN, network, operating system, database and application user access review to determine that logical access reviews were performed on a semi-annual basis.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Monitoring Activities				
CC4.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		The monitoring software is configured to alert IT personnel when thresholds have been exceeded.	Inspected the monitoring tool configurations and an example alert generated to determine that the monitoring software was configured to alert IT personnel when thresholds were exceeded.	No exceptions noted.
CC4.2	COSO Principle 17: The entity evaluates and communicates internal control deficiencies in a timely manner to those parties responsible for taking corrective action, including senior management and the board of directors, as appropriate.	Executive management meets quarterly with operational management to assess the effectiveness and performance of internal controls implemented within the environment.	Inspected the management meeting notes for a sample of quarters to determine that executive management met quarterly with operational management to assess the effectiveness and performance of internal controls implemented within the environment.	No exceptions noted.
		Responsible parties are defined and assigned to coordinate and monitor compliance and audit activities.	Inspected the organizational chart, the completed risk assessment and the information security roles and responsibilities to determine that responsible parties were defined and assigned to coordinate and monitor compliance and audit activities.	No exceptions noted.
		Management develops risk mitigation strategies, including the implementation of controls, to address risks identified during the risk assessment process.	Inspected the risk management policy to determine that management developed risk mitigation strategies, including the implementation of controls, to address risks identified during the risk assessment process.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Monitoring Activities				
CC4.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		The annual comprehensive risk assessment results are reviewed and approved by appropriate levels of management.	Inspected the risk assessment and management policies and procedures and the completed risk assessment to determine that the annual comprehensive risk assessment results were reviewed and approved by appropriate levels of management.	No exceptions noted.
		Vulnerabilities, deviations and control gaps identified from the compliance, control and risk assessments are communicated to those parties responsible for taking corrective actions.	Inquired of the Director of Information Security regarding vulnerability scans to determine that vulnerabilities, deviations and control failures/gaps identified from the various assessments performed on the environment were communicated to those parties responsible for taking corrective actions.	No exceptions noted.
			Inspected the risk assessment policy and the vulnerability protection policy to determine that vulnerabilities, deviations and control failures/gaps identified from the various assessments performed on the environment were communicated to those parties responsible for taking corrective actions.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Monitoring Activities				
CC4.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
			Inspected the completed risk assessment, the completed vulnerability scan results, and the completed penetration test results performed on the environment and supporting incident tickets for a sample of vulnerabilities identified from a vulnerability scan or penetration test to determine that vulnerabilities, deviations and control failures/gaps identified from the various assessments performed on the environment were communicated to those parties responsible for taking corrective actions.	Testing of the control activity disclosed that there were no vulnerabilities identified during the review period.
		Vulnerabilities, deviations and control failures/gaps identified from the various assessments performed on the environment are documented, investigated, and addressed.	Inquired of the Director of Information Security regarding vulnerability scans to determine that vulnerabilities, deviations and control failures/gaps identified from the various assessments performed on the environment were documented, investigated and addressed.	No exceptions noted.
			Inspected the risk assessment policy and the vulnerability protection policy to determine that vulnerabilities, deviations and control failures/gaps identified from the various assessments performed on the environment were documented, investigated and addressed.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Monitoring Activities				
CC4.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
			Inspected the completed risk assessment, the completed vulnerability scan results, and the completed penetration test results performed on the environment and supporting incident tickets for a sample of vulnerabilities identified from a vulnerability scan or penetration test to determine that vulnerabilities, deviations and control failures/gaps identified from the various assessments performed on the environment were documented, investigated and addressed.	Testing of the control activity disclosed that there were no vulnerabilities identified during the review period.
		Vulnerabilities, deviations and control failures/gaps identified from the various assessments performed on the environment are addressed by those parties responsible for taking corrective actions.	Inquired of the Director of Information Security regarding vulnerability scans to determine that vulnerabilities, deviations and control failures/gaps identified from the various assessments performed on the environment were addressed by those parties responsible for taking corrective actions.	No exceptions noted.
			Inspected the risk assessment policy and the vulnerability protection policy to determine that vulnerabilities, deviations and control failures/gaps identified from the various assessments performed on the environment were addressed by those parties responsible for taking corrective actions.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Monitoring Activities				
CC4.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
			Inspected the completed risk assessment, the completed vulnerability scan results, and the completed penetration test results performed on the environment and supporting incident tickets for a sample of vulnerabilities identified from a vulnerability scan or penetration test to determine that vulnerabilities, deviations and control failures/gaps identified from the various assessments performed on the environment were addressed by those parties responsible for taking corrective actions.	Testing of the control activity disclosed that there were no vulnerabilities identified during the review period.
		Management tracks whether vulnerabilities, deviations and control failures/gaps identified as part of the evaluations performed are addressed in a timely manner.	Inspected the information security management systems assessment review and the change management board meeting minutes to determine that management tracked whether vulnerabilities, deviations and control gaps identified as part of the evaluations performed were addressed in a timely manner.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Control Activities				
CC5.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
CC5.1	COSO Principle 10: The entity selects and develops control activities that contribute to the mitigation of risks to the achievement of objectives to acceptable levels.	Executive management maintains independence from those that operate the key controls implemented within the environment.	Inspected the organizational chart and the completed internal controls matrix to determine that executive management-maintained independence from those that operate the key controls implemented within the environment.	No exceptions noted.
		Executive management meets quarterly with operational management to assess the effectiveness and performance of internal controls implemented within the environment.	Inspected the management meeting notes for a sample of quarters to determine that executive management met quarterly with operational management to assess the effectiveness and performance of internal controls implemented within the environment.	No exceptions noted.
		Responsible parties are defined and assigned to coordinate and monitor compliance and audit activities.	Inspected the organizational chart, the completed risk assessment and the information security roles and responsibilities to determine that responsible parties were defined and assigned to coordinate and monitor compliance and audit activities.	No exceptions noted.
		Management develops risk mitigation strategies, including the implementation of controls, to address risks identified during the risk assessment process.	Inspected the risk management policy to determine that management developed risk mitigation strategies, including the implementation of controls, to address risks identified during the risk assessment process.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Control Activities				
CC5.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		Controls within the environment are modified and implemented to mitigate vulnerabilities, deviations and control gaps identified as part of the various evaluations performed.	Inspected the various assessments performed on the environment and the penetration test to determine that controls within the environment were modified and implemented to mitigate vulnerabilities, deviations and control failures/gaps identified as part of the various evaluations performed.	No exceptions noted.
		Performance of the internal controls implemented within the environment are assigned to appropriate process owners and operational personnel based on roles and responsibilities.	Inspected the organizational chart, the completed risk assessment and the information security roles and responsibilities to determine that performance of the internal controls implemented within the environment were assigned to appropriate process owners and operational personnel based on roles and responsibilities.	No exceptions noted.
		Management has documented the relevant controls in place for each key business or operational process.	Inspected the completed risk assessment and the information security roles and responsibilities to determine that management documented the relevant controls in place for each key business or operational process.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Control Activities				
CC5.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		Management has incorporated a variety of controls into their environment that include manual, automated, preventive, detective, and corrective controls.	Inspected the completed risk assessment and the information security roles and responsibilities to determine that management incorporated a variety of controls into their environment that included manual, automated, preventive, detective, and corrective controls.	No exceptions noted.
		Business continuity and disaster recovery plans are developed and updated on an annual basis.	Inspected the business continuity policy to determine that business continuity and disaster recovery plans were developed and updated on an annual basis.	No exceptions noted.
		Business continuity and disaster recovery plans are tested on an annual basis.	Inspected the completed business continuity and disaster recovery test results and the scheduled business continuity and disaster recovery test to determine that the business continuity and disaster recovery plans were tested on an annual basis.	No exceptions noted.
CC5.2	COSO Principle 11: The entity also selects and develops general control activities over technology to support the achievement of objectives.	Organizational and information security policies and procedures are documented and made available to personnel through the entity's intranet.	Inspected the information security policy and the entity's intranet to determine that organizational and information security policies and procedures were documented and made available to its personnel through the entity's intranet.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Control Activities				
CC5.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		Management has incorporated a variety of controls into their environment that include manual, automated, preventive, detective, and corrective controls.	Inspected the completed risk assessment and the information security roles and responsibilities to determine that management incorporated a variety of controls into their environment that included manual, automated, preventive, detective, and corrective controls.	No exceptions noted.
		Management has established controls around the entity's technology infrastructure to address the risks of incomplete, inaccurate, and unavailable technology processing.	Inspected the completed risk assessment and the information security roles and responsibilities to determine that management established controls around the entity's technology infrastructure to address the risks of incomplete, inaccurate, and unavailable technology processing.	No exceptions noted.
		The internal controls implemented around the entity's technology infrastructure include, but are not limited to: • Restricting access rights to authorized users • Limiting services to what is required for business operations • Authentication of access • Protecting the entity's assets from external threats	Inspected the completed risk assessment and the information security roles and responsibilities to determine that the internal controls implemented around the entity's technology infrastructure included, but were not limited to: • Restricting access rights to authorized users • Limiting services to what was required for business operations • Authentication of access • Protecting the entity's assets from external threats	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Control Activities				
CC5.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
CC5.3	COSO Principle 12: The entity deploys control activities through policies that establish what is expected and in procedures that put policies into action.	Executive management meets quarterly with operational management to assess the effectiveness and performance of internal controls implemented within the environment.	Inspected the management meeting notes for a sample of quarters to determine that executive management met quarterly with operational management to assess the effectiveness and performance of internal controls implemented within the environment.	No exceptions noted.
		Roles and responsibilities are defined in written job descriptions and communicated to personnel through the entity's intranet.	Inspected the job description for a sample of job roles and the entity's intranet to determine that roles and responsibilities were defined in written job descriptions and communicated to personnel through the entity's intranet.	No exceptions noted.
		Organizational and information security policies and procedures are documented and made available to personnel through the entity's intranet.	Inspected the information security policy and the entity’s intranet to determine that organizational and information security policies and procedures were documented and made available to its personnel through the entity’s intranet.	No exceptions noted.
		Responsible parties are defined and assigned to coordinate and monitor compliance and audit activities.	Inspected the organizational chart, the completed risk assessment and the information security roles and responsibilities to determine that responsible parties were defined and assigned to coordinate and monitor compliance and audit activities.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Control Activities				
CC5.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		Performance of the internal controls implemented within the environment are assigned to appropriate process owners and operational personnel based on roles and responsibilities.	Inspected the organizational chart, the completed risk assessment and the information security roles and responsibilities to determine that performance of the internal controls implemented within the environment were assigned to appropriate process owners and operational personnel based on roles and responsibilities.	No exceptions noted.
		Management has incorporated a variety of controls into their environment that include manual, automated, preventive, detective, and corrective controls.	Inspected the completed risk assessment and the information security roles and responsibilities to determine that management incorporated a variety of controls into their environment that included manual, automated, preventive, detective, and corrective controls.	No exceptions noted.
		The organizational and information security policies and procedures detail the day-to-day activities to be performed by personnel.	Inspected the information security policy to determine that the organizational and information security policies and procedures detailed the day-to-day activities to be performed by personnel.	No exceptions noted.
		Management has implemented controls that are built into the organizational and information security policies and procedures.	Inspected the organizational and information security policies and procedures, the completed risk assessment and the information security roles and responsibilities to determine that management implemented controls that were built into the organizational and information security policies and procedures.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Logical and Physical Access Controls				
CC6.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
CC6.1	The entity implements logical access security software, infrastructure, and architectures over protected information assets to protect them from security events to meet the entity's objectives.	Stored passwords are encrypted.	Inspected the encryption configurations for data at rest to determine that stored passwords were encrypted.	No exceptions noted.
		An inventory of system assets and components is maintained to classify and manage the information assets.	Inspected the inventory listing of system assets and components to determine that an inventory of system assets and components was maintained to classify and manage the information assets.	No exceptions noted.
		Documented policies and procedures are in place regarding system settings, authentication, access, and security monitoring.	Inspected the information security policies and procedures to determine that documented policies and procedures were in place regarding system settings, authentication, access, and security monitoring.	No exceptions noted.
		Privileged access to sensitive resources is restricted to authorized personnel.	Inquired of the Director of Information Security regarding the listings of privileged users to the network, operating system, database and application to determine that privileged access to sensitive resources was restricted to authorized personnel.	No exceptions noted.
			Inspected the listings of privileged users to the network, operating system, database and application to determine that privileged access to sensitive resources was restricted to authorized personnel.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Logical and Physical Access Controls				
CC6.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		Network user access is restricted via role-based security privileges defined within the access control system.	Inquired of the Director of Information Security regarding the network user listing and access rights to determine that network user access was restricted via role-based security privileges defined within the access control system.	No exceptions noted.
			Inspected the network user listing and access rights to determine that network user access was restricted via role-based security privileges defined within the access control system.	No exceptions noted.
		Network administrative access is restricted to authorized personnel.	Inquired of the Director of Information Security regarding the network administrator user listing and access rights to determine that network administrative access was restricted to authorized personnel.	No exceptions noted.
			Inspected the network administrator user listing and access rights to determine that network administrative access was restricted to authorized personnel.	No exceptions noted.
		Network users are authenticated via individually assigned user accounts, passwords, and multi-factor authentication.	Inquired of the Director of Information Security regarding network user authentication to determine that network users were authenticated via individually assigned user accounts and passwords.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Logical and Physical Access Controls				
CC6.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
			Inspected the network authentication settings to determine that network users were authenticated via individually assigned user accounts and passwords.	No exceptions noted.
		The network is configured to enforce password requirements that include: • Password history • Password age • Password length • Complexity	Inspected the network password settings to determine that the network was configured to enforce password requirements that included: • Password history • Password age • Password length • Complexity	No exceptions noted.
		Network account lockout configurations are in place that include: • Account lockout duration • Account lockout threshold • Account lockout counter reset	Inspected the network account lockout settings to determine that network account lockout configurations were in place that included: • Account lockout duration • Account lockout threshold • Account lockout counter reset	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Logical and Physical Access Controls				
CC6.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		Network audit logging configurations are in place that include: • Account logon events • Account management • Object access • Privilege use • Process tracking	Inspected the network audit logging configurations and an example network audit log extract to determine that network audit logging configurations were in place that included: • Account logon events • Account management • Object access • Privilege use • Process tracking	No exceptions noted.
		Network audit logs are maintained for review when needed.	Inquired of the Director of Information Security regarding the network audit logs to determine that network audit logs were maintained for review when needed.	No exceptions noted.
			Inspected the network audit log settings and an example network audit log extract to determine that network audit logs were maintained and reviewed as needed.	No exceptions noted.
		Operating system user access is restricted via role-based security privileges defined within the access control system.	Inquired of the Director of Information Security regarding the operating system user listing and access rights to determine that operating system user access was restricted via role-based security privileges defined within the access control system.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Logical and Physical Access Controls				
CC6.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
			Inspected the operating system user listing and access rights to determine that operating system user access was restricted via role-based security privileges defined within the access control system.	No exceptions noted.
		Operating system administrative access is restricted to authorized personnel.	Inquired of the Director of Information Security regarding the operating system administrative access to determine that operating system administrative access was restricted to authorized personnel.	No exceptions noted.
			Inspected the operating system administrator user listing and access rights to determine that operating system administrative access was restricted to authorized personnel.	No exceptions noted.
		Operating system users are authenticated via individually assigned user accounts, passwords, and multi-factor authentication.	Inquired of the Director of Information Security regarding the login process to determine that operating system users were authenticated via individually assigned user accounts, passwords, and multi-factor authentication.	No exceptions noted.
			Inspected the operating system authentication settings to determine that operating system users were authenticated via individually assigned user accounts, passwords, and multi-factor authentication.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Logical and Physical Access Controls				
CC6.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		Operating systems are configured to enforce password requirements that include: • Password history • Password length • Complexity • Password Expiration	Inspected the operating system password settings to determine that operating systems were configured to enforce password requirements that included: • Password history • Password length • Complexity • Password Expiration	No exceptions noted.
		Operating system audit logging settings are in place that include: • Account logon events • Account management • Logon events • Policy changes • System events	Inspected the operating system audit logging settings and an example operating system audit log extract to determine that operating system audit logging configurations were in place that included: • Account logon events • Account management • Logon events • Policy changes • System events	No exceptions noted.
		Operating system audit logs are maintained and reviewed as needed.	Inquired of the Director of Information Security regarding the operating system audit logs to determine that operating system audit logs were maintained for review when needed.	No exceptions noted.
			Inspected the operating system audit logging settings and an example operating system audit log extract to determine that operating system audit logs were maintained and reviewed as needed.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Logical and Physical Access Controls				
CC6.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		Database user access is restricted via role-based security privileges defined within the access control system.	Inquired of the Director of Information Security regarding database access to determine that databases user access was restricted via role-based security privileges defined within the access control system.	No exceptions noted.
			Inspected the database user listing and access rights to determine that database user access was restricted via role-based security privileges defined within the access control system.	No exceptions noted.
		Database administrative access is restricted to authorized personnel.	Inquired of the Director of Information Security regarding administrative access to determine that database administrative access was restricted to authorized personnel.	No exceptions noted.
			Inspected the database administrator user listing and access rights to determine that database administrative access was restricted to authorized personnel.	No exceptions noted.
		Database users are authenticated via individually assigned user accounts, passwords, and multi-factor authentication.	Inquired of the Director of Information Security regarding the login process to determine that database users were authenticated via individually assigned user accounts, passwords, and multi-factor authentication.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Logical and Physical Access Controls				
CC6.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
			Inspected the database authentication settings to determine that database users were authenticated via individually assigned user accounts, passwords, and multi-factor authentication.	No exceptions noted.
		Databases are configured to enforce password requirements that include: • Password history • Password length • Complexity • Password Expiration	Inspected the database password settings to determine that database was configured to enforce password requirements that included: • Password history • Password length • Complexity • Password Expiration	No exceptions noted.
		Database audit logging configurations are in place to log account logon events and process errors.	Inspected the database audit logging settings and an example database audit log extract to determine that database audit logging configurations were in place to log account logon events and process errors.	No exceptions noted.
		Database audit logs are maintained for review when needed.	Inquired of the Director of Information Security regarding the production databases audit logs to determine that the production databases audit logs were maintained for review when needed.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Logical and Physical Access Controls				
CC6.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
			Inspected an example production database audit log extract to determine that production databases audit logs were maintained for review when needed.	No exceptions noted.
		Application user access is restricted via role-based security privileges defined within the access control system.	Inquired of the Director of Information Security regarding application user access to determine that application user access was restricted via role-based security privileges defined within the access control system.	No exceptions noted.
			Inspected the application user listing and access roles to determine that application user access was restricted via role-based security privileges defined within the access control system.	No exceptions noted.
		Application administrative access is restricted to authorized personnel.	Inquired of the Director of Information Security regarding application administrative access to determine that application administrative access was restricted to authorized personnel.	No exceptions noted.
			Inspected the application administrator listing and access roles to determine that application administrative access was restricted to authorized personnel.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Logical and Physical Access Controls				
CC6.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		Application users are authenticated via individually assigned user accounts, passwords, and multi-factor authentication.	Inquired of the Director of Information Security regarding the login process to determine that application users were authenticated via individually assigned user accounts, passwords, and multi-factor authentication.	No exceptions noted.
			Inspected the application authentication settings to determine that application users were authenticated via individually assigned user accounts, passwords, and multi-factor authentication.	No exceptions noted.
		The application is configured to enforce password requirements that include: • Password history • Password length • Complexity • Password Expiration	Inspected the application password configurations to determine that applications were configured to enforce password requirements that included: • Password history • Password length • Complexity • Password Expiration	No exceptions noted.
		Application audit policy settings are in place that include: • Account logon events • Account management • System events	Inspected the application audit logging settings and an example application audit log extract to determine that application audit logging configurations were in place that included: • Account logon events • Account management • System events	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Logical and Physical Access Controls				
CC6.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		Application audit logs are maintained for review when needed.	Inquired of the Director of Information Security regarding application audit logs to determine that application audit logs were maintained for review when needed.	No exceptions noted.
			Inspected an example production application audit log extract to determine that production application audit logs were maintained for review when needed.	No exceptions noted.
		VPN user access is restricted via role-based security privileges defined within the access control system.	Inquired of the Director of Information Security regarding VPN access to determine that VPN user access was restricted via role-based security privileges defined within the access control system.	No exceptions noted.
			Inspected the VPN user listing and access rights to determine that VPN user access was restricted via role-based security privileges defined within the access control system.	No exceptions noted.
		The ability to administer VPN access is restricted to authorized personnel.	Inquired of the Director of Information Security regarding administrative access to the VPN to determine that the ability to administer VPN access was restricted to authorized personnel.	No exceptions noted.
			Inspected the VPN administrator listing to determine that the ability to administer VPN access was restricted to authorized personnel.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Logical and Physical Access Controls				
CC6.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		Users are authenticated via multi-factor authentication (username, password, and token) prior to being granted remote access to the environment.	Inquired of the Director of Information Security regarding remote access to determine that users were authenticated via multi-factor authentication (username, password, and Token) prior to being granted remote access to the environment.	No exceptions noted.
			Inspected the VPN authentication settings to determine that users were authenticated via multi-factor authentication (username, password, and token) prior to being granted remote access to the system.	No exceptions noted.
		The entity's various networks are segmented to keep information and data isolated and restricted to authorized personnel.	Inspected the network diagram, the demilitarized zone (DMZ) settings and the firewall settings to determine that the entity's various networks were segmented to keep information and data isolated and restricted to authorized personnel.	No exceptions noted.
		Data coming into the environment is secured and monitored through the use of firewalls.	Inspected the firewall settings and the network diagram to determine that data coming into the environment was secured and monitored through the use of firewalls.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Logical and Physical Access Controls				
CC6.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		Server certificate-based authentication is used as part of the Secure Socket Layer (SSL) encryption with a trusted certificate authority.	Inspected the encryption configurations for data in transit and digital certificates to determine that server certificate-based authentication was used as part of the SSL encryption with a trusted certificate authority.	No exceptions noted.
		Critical data is stored in encrypted format using software supporting the Advanced Encryption Standard (AES).	Inspected the encryption configurations for data at rest to determine that critical data was stored in encrypted format using AES.	No exceptions noted.
		A user access review is performed on a semi-annual basis to validate the logical access to systems is appropriate for all personnel.	Inquired of the Director of Information Security regarding user access reviews to determine that logical access reviews were performed on a semi-annual basis.	No exceptions noted.
			Inspected the completed VPN, network, operating system, database and application user access review to determine that logical access reviews were performed on a semi-annual basis.	No exceptions noted.
		Logical access to systems is approved and granted to an employee as a component of the hiring process.	Inquired of the Director of Information Security regarding the hiring process to determine that logical access to systems was approved and granted to personnel as a component of the hiring process.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Logical and Physical Access Controls				
CC6.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
			Inspected the recruitment and selection process, network, database, application, and VPN user listings, and the completed user onboarding ticket for a sample of new hires to determine that logical access to systems was approved and granted to an employee as a component of the hiring process.	No exceptions noted.
		Logical access to systems is revoked as a component of the termination process.	Inquired of the Director of Information Security regarding the termination process to determine that logical access to systems was revoked as a component of the termination process.	No exceptions noted.
			Inspected the offboarding process, the network, database, application, and VPN user listings, and the completed user offboarding tickets for a sample of terminated employees to determine that logical access to systems was revoked for an employee as a component of the termination process.	No exceptions noted.
		Privileged access to sensitive resources is restricted to authorized personnel.	Inquired of the Director of Information Security regarding the listings of privileged users to the network, operating system, database and application to determine that privileged access to sensitive resources was restricted to authorized personnel.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Logical and Physical Access Controls				
CC6.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
			Inspected the listings of privileged users to the network, operating system, database and application to determine that privileged access to sensitive resources was restricted to authorized personnel.	No exceptions noted.
CC6.2	Prior to issuing system credentials and granting system access, the entity registers and authorizes new internal and external users whose access is administered by the entity. For those users whose access is administered by the entity, user system credentials are removed when user access is no longer authorized.	Documented policies and procedures are in place regarding system settings, authentication, access, and security monitoring.	Inspected the information security policies and procedures to determine that documented policies and procedures were in place regarding system settings, authentication, access, and security monitoring.	No exceptions noted.
		Privileged access to sensitive resources is restricted to authorized personnel.	Inquired of the Director of Information Security regarding the listings of privileged users to the network, operating system, database and application to determine that privileged access to sensitive resources was restricted to authorized personnel.	No exceptions noted.
			Inspected the listings of privileged users to the network, operating system, database and application to determine that privileged access to sensitive resources was restricted to authorized personnel.	No exceptions noted.
		A user access review is performed on a semi-annual basis to validate the logical access to systems is appropriate for all personnel.	Inquired of the Director of Information Security regarding user access reviews to determine that logical access reviews were performed on a semi-annual basis.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Logical and Physical Access Controls				
CC6.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
			Inspected the completed VPN, network, operating system, database and application user access review to determine that logical access reviews were performed on a semi-annual basis.	No exceptions noted.
		Logical access to systems is approved and granted to an employee as a component of the hiring process.	Inquired of the Director of Information Security regarding the hiring process to determine that logical access to systems was approved and granted to personnel as a component of the hiring process.	No exceptions noted.
			Inspected the recruitment and selection process, network, database, application, and VPN user listings, and the completed user onboarding ticket for a sample of new hires to determine that logical access to systems was approved and granted to an employee as a component of the hiring process.	No exceptions noted.
		Logical access to systems is revoked as a component of the termination process.	Inquired of the Director of Information Security regarding the termination process to determine that logical access to systems was revoked as a component of the termination process.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Logical and Physical Access Controls				
CC6.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
			Inspected the offboarding process, the network, database, application, and VPN user listings, and the completed user offboarding tickets for a sample of terminated employees to determine that logical access to systems was revoked for an employee as a component of the termination process.	No exceptions noted.
		Privileged access to sensitive resources is restricted to authorized personnel.	Inquired of the Director of Information Security regarding the listings of privileged users to the network, operating system, database and application to determine that privileged access to sensitive resources was restricted to authorized personnel.	No exceptions noted.
			Inspected the listings of privileged users to the network, operating system, database and application to determine that privileged access to sensitive resources was restricted to authorized personnel.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Logical and Physical Access Controls				
CC6.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
CC6.3	The entity authorizes, modifies, or removes access to data, software, functions, and other protected information assets based on roles, responsibilities, or the system design and changes, giving consideration to the concepts of least privilege and segregation of duties, to meet the entity's objectives.	Documented policies and procedures are in place regarding system settings, authentication, access, and security monitoring.	Inspected the information security policies and procedures to determine that documented policies and procedures were in place regarding system settings, authentication, access, and security monitoring.	No exceptions noted.
		Privileged access to sensitive resources is restricted to authorized personnel.	Inquired of the Director of Information Security regarding the listings of privileged users to the network, operating system, database and application to determine that privileged access to sensitive resources was restricted to authorized personnel.	No exceptions noted.
			Inspected the listings of privileged users to the network, operating system, database and application to determine that privileged access to sensitive resources was restricted to authorized personnel.	No exceptions noted.
		Network user access is restricted via role-based security privileges defined within the access control system.	Inquired of the Director of Information Security regarding the network user listing and access rights to determine that network user access was restricted via role-based security privileges defined within the access control system.	No exceptions noted.
			Inspected the network user listing and access rights to determine that network user access was restricted via role-based security privileges defined within the access control system.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Logical and Physical Access Controls				
CC6.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		Operating system user access is restricted via role-based security privileges defined within the access control system.	Inquired of the Director of Information Security regarding the operating system user listing and access rights to determine that operating system user access was restricted via role-based security privileges defined within the access control system.	No exceptions noted.
			Inspected the operating system user listing and access rights to determine that operating system user access was restricted via role-based security privileges defined within the access control system.	No exceptions noted.
		Database user access is restricted via role-based security privileges defined within the access control system.	Inquired of the Director of Information Security regarding database access to determine that databases user access was restricted via role-based security privileges defined within the access control system.	No exceptions noted.
			Inspected the database user listing and access rights to determine that database user access was restricted via role-based security privileges defined within the access control system.	No exceptions noted.
		Application user access is restricted via role-based security privileges defined within the access control system.	Inquired of the Director of Information Security regarding application user access to determine that application user access was restricted via role-based security privileges defined within the access control system.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Logical and Physical Access Controls				
CC6.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
			Inspected the application user listing and access roles to determine that application user access was restricted via role-based security privileges defined within the access control system.	No exceptions noted.
		A user access review is performed on a semi-annual basis to validate the logical access to systems is appropriate for all personnel.	Inquired of the Director of Information Security regarding user access reviews to determine that logical access reviews were performed on a semi-annual basis.	No exceptions noted.
			Inspected the completed VPN, network, operating system, database and application user access review to determine that logical access reviews were performed on a semi-annual basis.	No exceptions noted.
		Logical access to systems is approved and granted to an employee as a component of the hiring process.	Inquired of the Director of Information Security regarding the hiring process to determine that logical access to systems was approved and granted to personnel as a component of the hiring process.	No exceptions noted.
			Inspected the recruitment and selection process, network, database, application, and VPN user listings, and the completed user onboarding ticket for a sample of new hires to determine that logical access to systems was approved and granted to an employee as a component of the hiring process.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Logical and Physical Access Controls				
CC6.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		Logical access to systems is revoked as a component of the termination process.	Inquired of the Director of Information Security regarding the termination process to determine that logical access to systems was revoked as a component of the termination process.	No exceptions noted.
			Inspected the offboarding process, the network, database, application, and VPN user listings, and the completed user offboarding tickets for a sample of terminated employees to determine that logical access to systems was revoked for an employee as a component of the termination process.	No exceptions noted.
		Privileged access to sensitive resources is restricted to authorized personnel.	Inquired of the Director of Information Security regarding the listings of privileged users to the network, operating system, database and application to determine that privileged access to sensitive resources was restricted to authorized personnel.	No exceptions noted.
			Inspected the listings of privileged users to the network, operating system, database and application to determine that privileged access to sensitive resources was restricted to authorized personnel.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Logical and Physical Access Controls				
CC6.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
CC6.4	The entity restricts physical access to facilities and protected information assets (for example, data center facilities, back-up media storage, and other sensitive locations) to authorized personnel to meet the entity's objectives.	This criterion is the responsibility of the subservice organization. Refer to the "Subservice Organizations" section above for controls managed by the subservice organization.	Not applicable.	Not applicable.
CC6.5	The entity discontinues logical and physical protections over physical assets only after the ability to read or recover data and software from those assets has been diminished and is no longer required to meet the entity's objectives.	Policies and procedures are in place to guide personnel in data, hardware and software disposal and destruction.	Inspected the data disposal and data retention policy to determine that policies and procedures were in place to guide personnel in data, hardware and software disposal and destruction.	No exceptions noted.
		The entity purges data stored on cloud backups, per a defined schedule.	Inspected the data disposal and data retention policy to determine that the entity purged data stored on cloud backups, per a defined schedule.	No exceptions noted.
		Data that is no longer required is disposed of and rendered unreadable to meet the entity's objectives.	Inspected the data disposal and destruction policies and procedures and the destruction certificate for a sample of requests to dispose of data, purge a system, or physically destroy a system to determine that data that was no longer required was disposed of and rendered unreadable to meet the entity's objectives.	No exceptions noted.
CC6.6	The entity implements logical access security measures to protect against threats from sources outside its system boundaries.	VPN user access is restricted via role-based security privileges defined within the access control system.	Inquired of the Director of Information Security regarding VPN access to determine that VPN user access was restricted via role-based security privileges defined within the access control system.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Logical and Physical Access Controls				
CC6.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
			Inspected the VPN user listing and access rights to determine that VPN user access was restricted via role-based security privileges defined within the access control system.	No exceptions noted.
		Users are authenticated via multi-factor authentication (username, password, and token) prior to being granted remote access to the environment.	Inquired of the Director of Information Security regarding remote access to determine that users were authenticated via multi-factor authentication (username, password, and Token) prior to being granted remote access to the environment.	No exceptions noted.
			Inspected the VPN authentication settings to determine that users were authenticated via multi-factor authentication (username, password, and token) prior to being granted remote access to the system.	No exceptions noted.
		Server certificate-based authentication is used as part of the SSL encryption with a trusted certificate authority.	Inspected the encryption configurations for data in transit and digital certificates to determine that server certificate-based authentication was used as part of the SSL encryption with a trusted certificate authority.	No exceptions noted.
		Critical data is stored in encrypted format using software supporting the AES.	Inspected the encryption configurations for data at rest to determine that critical data was stored in encrypted format using AES.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Logical and Physical Access Controls				
CC6.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		VPN, SSL and other encryption technologies are used for defined points of connectivity.	Inspected the encryption configurations, VPN authentication configurations and digital certificates to determine that VPN, SSL and other encryption technologies were used for defined points of connectivity.	No exceptions noted.
		Remote connectivity users are authenticated via an authorized user account and password before establishing a VPN session.	Inquired of the Director of Information Security regarding remote connectivity to determine that remote connectivity users were authenticated via an authorized user account and password before establishing a VPN session.	No exceptions noted.
			Inspected the VPN authentication configurations to determine that remote connectivity users were authenticated via an authorized user account and password before establishing a VPN session.	No exceptions noted.
		Logical access to stored data is restricted to authorized personnel.	Inquired of the Director of Information Security regarding access to stored data to determine that logical access to stored data was restricted to authorized personnel.	No exceptions noted.
			Inspected the database user listing and access rights to determine that logical access to stored data was restricted to authorized personnel.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Logical and Physical Access Controls				
CC6.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		A firewall is in place to filter unauthorized inbound network traffic from the internet.	Inspected the network diagram and the firewall rule sets for the production environments to determine that a firewall was in place to filter unauthorized inbound network traffic from the Internet.	No exceptions noted.
		The firewall system is configured to deny any type of network connection that is not explicitly authorized by a firewall system rule.	Inspected the network diagram and the firewall settings to determine that the firewall system was configured to deny any type of network connection that was not explicitly authorized by a firewall system rule.	No exceptions noted.
		Antivirus software is installed on workstations to detect and prevent the transmission of data or files that contain certain virus signatures recognized by the antivirus software.	Inspected the centralized antivirus software dashboard console to determine that centralized antivirus software was installed on workstations to detect and prevent the transmission of data or files that contained certain virus signatures recognized by the antivirus software.	No exceptions noted.
		The antivirus software provider pushes updates to the installed antivirus software as new updates/signatures are available.	Inspected the centralized antivirus settings to determine that the antivirus software provider pushed updates to the installed antivirus software as new updates/signatures were available.	No exceptions noted.
		The antivirus software is configured to scan workstations on a real-time basis.	Inspected the centralized antivirus settings to determine that the antivirus software was configured to scan workstations on a real-time basis.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Logical and Physical Access Controls				
CC6.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		Use of removable media is prohibited by policy except when authorized by management.	Inspected the removable media policy to determine that the use of removable media was prohibited by policy except when authorized by management.	No exceptions noted.
CC6.7	The entity restricts the transmission, movement, and removal of information to authorized internal and external users and processes, and protects it during transmission, movement, or removal to meet the entity's objectives.	Users are authenticated via multi-factor authentication (username, password, and token) prior to being granted remote access to the environment.	Inquired of the Director of Information Security regarding remote access to determine that users were authenticated via multi-factor authentication (username, password, and Token) prior to being granted remote access to the environment.	No exceptions noted.
			Inspected the VPN authentication settings to determine that users were authenticated via multi-factor authentication (username, password, and token) prior to being granted remote access to the system.	No exceptions noted.
		Server certificate-based authentication is used as part of the SSL encryption with a trusted certificate authority.	Inspected the encryption configurations for data in transit and digital certificates to determine that server certificate-based authentication was used as part of the SSL encryption with a trusted certificate authority.	No exceptions noted.
		Critical data is stored in encrypted format using software supporting the AES.	Inspected the encryption configurations for data at rest to determine that critical data was stored in encrypted format using AES.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Logical and Physical Access Controls				
CC6.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		VPN, SSL and other encryption technologies are used for defined points of connectivity.	Inspected the encryption configurations, VPN authentication configurations and digital certificates to determine that VPN, SSL and other encryption technologies were used for defined points of connectivity.	No exceptions noted.
		Remote connectivity users are authenticated via an authorized user account and password before establishing a VPN session.	Inquired of the Director of Information Security regarding remote connectivity to determine that remote connectivity users were authenticated via an authorized user account and password before establishing a VPN session.	No exceptions noted.
			Inspected the VPN authentication configurations to determine that remote connectivity users were authenticated via an authorized user account and password before establishing a VPN session.	No exceptions noted.
		Logical access to stored data is restricted to authorized personnel.	Inquired of the Director of Information Security regarding access to stored data to determine that logical access to stored data was restricted to authorized personnel.	No exceptions noted.
			Inspected the database user listing and access rights to determine that logical access to stored data was restricted to authorized personnel.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Logical and Physical Access Controls				
CC6.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		A firewall is in place to filter unauthorized inbound network traffic from the internet.	Inspected the network diagram and the firewall rule sets for the production environments to determine that a firewall was in place to filter unauthorized inbound network traffic from the Internet.	No exceptions noted.
		The firewall system is configured to deny any type of network connection that is not explicitly authorized by a firewall system rule.	Inspected the network diagram and the firewall settings to determine that the firewall system was configured to deny any type of network connection that was not explicitly authorized by a firewall system rule.	No exceptions noted.
		Use of removable media is prohibited by policy except when authorized by management.	Inspected the removable media policy to determine that the use of removable media was prohibited by policy except when authorized by management.	No exceptions noted.
		The ability to recall backed up data is restricted to authorized personnel.	Inquired of the Director of Information Security regarding recalling backed up data to determine that the ability to recall backed up data was restricted to authorized personnel.	No exceptions noted.
			Inspected the list of users with the ability to restore backups from the third-party cloud vendor to determine that the ability to recall backed up data was restricted to authorized personnel.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Logical and Physical Access Controls				
CC6.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		Backup media is replicated off-site by a third-party vendor daily.	Inspected the executed contract with the cloud backup vendor and the cloud backup vendor configurations and a backup log for an example day to determine that backup media was replicated off-site by a third-party vendor daily.	No exceptions noted.
		Backup media is stored in an encrypted format.	Inspected the encryption configurations for the backups to determine that backup media was stored in an encrypted format.	No exceptions noted.
CC6.8	The entity implements controls to prevent or detect and act upon the introduction of unauthorized or malicious software to meet the entity's objectives.	Monitoring software is used to identify and evaluate ongoing system performance, capacity, security threats, changing resource utilization needs and unusual system activity.	Inspected the monitoring tool configurations, the centralized antivirus software dashboard console and the firewall settings to determine that monitoring software was used to identify and evaluate ongoing system performance, capacity, security threats, changing resource utilization needs and unusual system activity.	No exceptions noted.
		Antivirus software is installed on workstations to detect and prevent the transmission of data or files that contain certain virus signatures recognized by the antivirus software.	Inspected the centralized antivirus software dashboard console to determine that centralized antivirus software was installed on workstations to detect and prevent the transmission of data or files that contained certain virus signatures recognized by the antivirus software.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Logical and Physical Access Controls				
CC6.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		The antivirus software provider pushes updates to the installed antivirus software as new updates/signatures are available.	Inspected the centralized antivirus settings to determine that the antivirus software provider pushed updates to the installed antivirus software as new updates/signatures were available.	No exceptions noted.
		The antivirus software is configured to scan workstations on a real-time basis.	Inspected the centralized antivirus settings to determine that the antivirus software was configured to scan workstations on a real-time basis.	No exceptions noted.
		The ability to install applications and software on workstations is restricted to authorized personnel.	Inquired of the Director of Information Security regarding the applications and software to determine that the ability to install applications and software on workstations was restricted to authorized personnel.	No exceptions noted.
			Inspected the denial notification from an attempt to install software and the workstations application restriction configurations to determine that a warning notification appeared when an employee attempted to download an application or software.	No exceptions noted.
		The ability to migrate changes into the production environment is restricted to authorized and appropriate users.	Inquired of the Director of Information Security regarding the ability to migrate changes into the production environment to determine that the ability to migrate changes into the production environment was restricted to authorized and appropriate users.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Logical and Physical Access Controls				
CC6.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
			Inspected the list of users with the ability to implement changes into the production environment to determine that the ability to migrate changes into the production environment was restricted to authorized and appropriate users.	No exceptions noted.
		Code repository is utilized to help detect unauthorized changes within the production environment.	Inspected the code repository configurations to determine that a code repository was utilized to help detect unauthorized changes within the production environment.	No exceptions noted.
		The code repository is configured to notify IT personnel via e-mail alert when a change to the production application code files is detected.	Inspected the code repository notification configurations and an example alert generated from the code repository to determine that the code repository was configured to notify IT personnel via e-mail alert when a change to the production application code files was detected.	No exceptions noted.
		Documented change control policies and procedures are in place to guide personnel in the change management process.	Inspected the change management policies and procedures to determine that documented change control policies and procedures were in place to guide personnel in the change management process.	No exceptions noted.
		The monitoring software is configured to alert IT personnel when thresholds have been exceeded.	Inspected the monitoring tool configurations and an example alert generated to determine that the monitoring software was configured to alert IT personnel when thresholds were exceeded.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
System Operations				
CC7.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
CC7.1	To meet its objectives, the entity uses detection and monitoring procedures to identify (1) changes to configurations that result in the introduction of new vulnerabilities, and (2) susceptibilities to newly discovered vulnerabilities.	Monitoring software is used to identify and evaluate ongoing system performance, capacity, security threats, changing resource utilization needs and unusual system activity.	Inspected the monitoring tool configurations, the centralized antivirus software dashboard console and the firewall settings to determine that monitoring software was used to identify and evaluate ongoing system performance, capacity, security threats, changing resource utilization needs and unusual system activity.	No exceptions noted.
		Vulnerability scans are performed daily on the environment to identify control gaps and vulnerabilities.	Inspected the completed vulnerability scan results for a sample of days to determine that vulnerability scans were performed daily on the environment to identify control gaps and vulnerabilities.	No exceptions noted.
		A third party performs a penetration testing annually to identify and exploit vulnerabilities identified within the environment.	Inspected the completed penetration test results to determine that a third party performed a penetration testing annually to identify and exploit vulnerabilities identified within the environment.	No exceptions noted.
		A firewall is in place to filter unauthorized inbound network traffic from the internet.	Inspected the network diagram and the firewall rule sets for the production environments to determine that a firewall was in place to filter unauthorized inbound network traffic from the Internet.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
System Operations				
CC7.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		The firewall system is configured to deny any type of network connection that is not explicitly authorized by a firewall system rule.	Inspected the network diagram and the firewall settings to determine that the firewall system was configured to deny any type of network connection that was not explicitly authorized by a firewall system rule.	No exceptions noted.
		Use of removable media is prohibited by policy except when authorized by management.	Inspected the removable media policy to determine that the use of removable media was prohibited by policy except when authorized by management.	No exceptions noted.
		Code repository is utilized to help detect unauthorized changes within the production environment.	Inspected the code repository configurations to determine that a code repository was utilized to help detect unauthorized changes within the production environment.	No exceptions noted.
		The code repository is configured to notify IT personnel via e-mail alert when a change to the production application code files is detected.	Inspected the code repository notification configurations and an example alert generated from the code repository to determine that the code repository was configured to notify IT personnel via e-mail alert when a change to the production application code files was detected.	No exceptions noted.
		Management defined configuration standards in the information security policies and procedures.	Inspected the information security policies and procedures to determine that management defined configuration standards in the information security policies and procedures.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
System Operations				
CC7.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		The monitoring software is configured to alert IT personnel when thresholds have been exceeded.	Inspected the monitoring tool configurations and an example alert generated to determine that the monitoring software was configured to alert IT personnel when thresholds were exceeded.	No exceptions noted.
		Policies and procedures are in place regarding detection, logging, and monitoring of unknown or unauthorized components into the environment.	Inspected the information security policy to determine that policies and procedures were in place regarding detection, logging, and monitoring of unknown or unauthorized components into the environment.	No exceptions noted.
CC7.2	The entity monitors system components and the operation of those components for anomalies that are indicative of malicious acts, natural disasters, and errors affecting the entity's ability to meet its objectives; anomalies are analyzed to determine whether they represent security events.	Management monitors the effectiveness of detection tools and controls implemented within the environment.	Inspected the information security management systems assessment review and the change management board meeting minutes to determine that management monitored the effectiveness of detection tools and controls implemented within the environment.	No exceptions noted.
		Monitoring software is used to identify and evaluate ongoing system performance, capacity, security threats, changing resource utilization needs and unusual system activity.	Inspected the monitoring tool configurations, the centralized antivirus software dashboard console and the firewall settings to determine that monitoring software was used to identify and evaluate ongoing system performance, capacity, security threats, changing resource utilization needs and unusual system activity.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
System Operations				
CC7.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		Network account lockout configurations are in place that include: • Account lockout duration • Account lockout threshold • Account lockout counter reset	Inspected the network account lockout settings to determine that network account lockout configurations were in place that included: • Account lockout duration • Account lockout threshold • Account lockout counter reset	No exceptions noted.
		Network audit logging configurations are in place that include: • Account logon events • Account management • Object access • Privilege use • Process tracking	Inspected the network audit logging configurations and an example network audit log extract to determine that network audit logging configurations were in place that included: • Account logon events • Account management • Object access • Privilege use • Process tracking	No exceptions noted.
		Network audit logs are maintained for review when needed.	Inquired of the Director of Information Security regarding the network audit logs to determine that network audit logs were maintained for review when needed.	No exceptions noted.
			Inspected the network audit log settings and an example network audit log extract to determine that network audit logs were maintained and reviewed as needed.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
System Operations				
CC7.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		Operating system audit logging settings are in place that include: • Account logon events • Account management • Logon events • Policy changes • System events	Inspected the operating system audit logging settings and an example operating system audit log extract to determine that operating system audit logging configurations were in place that included: • Account logon events • Account management • Logon events • Policy changes • System events	No exceptions noted.
		Operating system audit logs are maintained and reviewed as needed.	Inquired of the Director of Information Security regarding the operating system audit logs to determine that operating system audit logs were maintained for review when needed.	No exceptions noted.
			Inspected the operating system audit logging settings and an example operating system audit log extract to determine that operating system audit logs were maintained and reviewed as needed.	No exceptions noted.
		Database audit logging configurations are in place to log account logon events and process errors.	Inspected the database audit logging settings and an example database audit log extract to determine that database audit logging configurations were in place to log account logon events and process errors.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
System Operations				
CC7.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		Database audit logs are maintained for review when needed.	Inquired of the Director of Information Security regarding the production databases audit logs to determine that the production databases audit logs were maintained for review when needed.	No exceptions noted.
			Inspected an example production database audit log extract to determine that production databases audit logs were maintained for review when needed.	No exceptions noted.
		Application audit policy settings are in place that include: • Account logon events • Account management • System events	Inspected the application audit logging settings and an example application audit log extract to determine that application audit logging configurations were in place that included: • Account logon events • Account management • System events	No exceptions noted.
		Application audit logs are maintained for review when needed.	Inquired of the Director of Information Security regarding application audit logs to determine that application audit logs were maintained for review when needed.	No exceptions noted.
			Inspected an example production application audit log extract to determine that production application audit logs were maintained for review when needed.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
System Operations				
CC7.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		A firewall is in place to filter unauthorized inbound network traffic from the internet.	Inspected the network diagram and the firewall rule sets for the production environments to determine that a firewall was in place to filter unauthorized inbound network traffic from the Internet.	No exceptions noted.
		The firewall system is configured to deny any type of network connection that is not explicitly authorized by a firewall system rule.	Inspected the network diagram and the firewall settings to determine that the firewall system was configured to deny any type of network connection that was not explicitly authorized by a firewall system rule.	No exceptions noted.
		Antivirus software is installed on workstations to detect and prevent the transmission of data or files that contain certain virus signatures recognized by the antivirus software.	Inspected the centralized antivirus software dashboard console to determine that centralized antivirus software was installed on workstations to detect and prevent the transmission of data or files that contained certain virus signatures recognized by the antivirus software.	No exceptions noted.
		The antivirus software provider pushes updates to the installed antivirus software as new updates/signatures are available.	Inspected the centralized antivirus settings to determine that the antivirus software provider pushed updates to the installed antivirus software as new updates/signatures were available.	No exceptions noted.
		The antivirus software is configured to scan workstations on a real-time basis.	Inspected the centralized antivirus settings to determine that the antivirus software was configured to scan workstations on a real-time basis.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
System Operations				
CC7.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		Use of removable media is prohibited by policy except when authorized by management.	Inspected the removable media policy to determine that the use of removable media was prohibited by policy except when authorized by management.	No exceptions noted.
		Code repository is utilized to help detect unauthorized changes within the production environment.	Inspected the code repository configurations to determine that a code repository was utilized to help detect unauthorized changes within the production environment.	No exceptions noted.
		The code repository is configured to notify IT personnel via e-mail alert when a change to the production application code files is detected.	Inspected the code repository notification configurations and an example alert generated from the code repository to determine that the code repository was configured to notify IT personnel via e-mail alert when a change to the production application code files was detected.	No exceptions noted.
		The monitoring software is configured to alert IT personnel when thresholds have been exceeded.	Inspected the monitoring tool configurations and an example alert generated to determine that the monitoring software was configured to alert IT personnel when thresholds were exceeded.	No exceptions noted.
		Policies and procedures are in place regarding detection, logging, and monitoring of unknown or unauthorized components into the environment.	Inspected the information security policy to determine that policies and procedures were in place regarding detection, logging, and monitoring of unknown or unauthorized components into the environment.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
System Operations				
CC7.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		Documented incident response and escalation procedures for reporting security incidents are in place to guide users in identifying, reporting and mitigating failures, incidents, concerns, and other complaints.	Inspected the incident response policy to determine that documented incident response and escalation procedures for reporting security incidents were in place to guide users in identifying, reporting and mitigating failures, incidents, concerns, and other complaints.	No exceptions noted.
		Management reviews reports on a quarterly basis summarizing incident, root cause of incidents, and corrective action plans and as part of the review, management identifies the need for system changes and implementation of additional controls based on incident patterns and root causes.	Inspected the information security management systems assessment review and the change management board meeting minutes for a sample of quarters to determine that management reviewed reports on a quarterly basis summarizing incident, root cause of incidents, and corrective action plans and as part of the review, management identified the need for system changes and implementation of additional controls based on incident patterns and root causes.	No exceptions noted.
CC7.3	The entity evaluates security events to determine whether they could or have resulted in a failure of the entity to meet its objectives (security incidents) and, if so, takes actions to prevent or address such failures.	Identified incidents are analyzed, classified and prioritized based on system impact to determine the appropriate containment strategy, including a determination of the appropriate response time frame and the determination and execution of the containment approach.	Inquired of the Director of Information Security regarding incident handling to determine that identified incidents were analyzed, classified and prioritized based on system impact to determine the appropriate containment strategy, including a determination of the appropriate response time frame and the determination and execution of the containment approach.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
System Operations				
CC7.0	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
			Inspected the incident management policy to determine that identified incidents were analyzed, classified and prioritized based on system impact to determine the appropriate containment strategy, including a determination of the appropriate response time frame and the determination and execution of the containment approach.	No exceptions noted.
			Inspected the supporting ticket and the incident report for a sample of incidents to determine that identified incidents were analyzed, classified and prioritized based on system impact to determine the appropriate containment strategy, including a determination of the appropriate response time frame and the determination and execution of the containment approach.	No exceptions noted.
		Documented incident response and escalation procedures for reporting security incidents are in place to guide users in identifying, reporting and mitigating failures, incidents, concerns, and other complaints.	Inspected the incident response policy to determine that documented incident response and escalation procedures for reporting security incidents were in place to guide users in identifying, reporting and mitigating failures, incidents, concerns, and other complaints.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
System Operations				
CC7.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		The incident response and escalation procedures are reviewed at least annually for effectiveness.	Inspected the revision history of the incident response policies and procedures to determine that the incident response and escalation procedures were reviewed at least annually for effectiveness.	No exceptions noted.
		The incident response policies and procedures define the classification of incidents based on its severity.	Inquired of the Director of Information Security regarding incident handling to determine that the incident response policies and procedures defined the classification of incidents based on its severity.	No exceptions noted.
			Inspected the incident response policy to determine that the incident response policies and procedures defined the classification of incidents based on its severity.	No exceptions noted.
			Inspected the supporting ticket and the incident report for a sample of incidents to determine that the incident response policies and procedures defined the classification of incidents based on its severity.	No exceptions noted.
		Resolution of incidents are documented within the ticket and communicated to affected users.	Inquired of the Director of Information Security regarding incident handling to determine that resolution of incidents was documented within the ticket and communicated to affected users.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
System Operations				
CC7.0	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
			Inspected the incident response policy to determine that resolution of incidents was documented within the ticket and communicated to affected users.	No exceptions noted.
			Inspected the supporting ticket and the incident report for a sample of incidents to determine that resolution of incidents was documented within the ticket and communicated to affected users.	No exceptions noted.
		Incidents are documented and tracked in a standardized ticketing system and updated to reflect the planned incident and problem resolution.	Inquired of the Director of Information Security regarding incident handling to determine that incidents were documented and tracked in a standardized ticketing system and updated to reflect the planned incident and problem resolution.	No exceptions noted.
			Inspected the incident response policy to determine that incidents were documented and tracked in a standardized ticketing system and updated to reflect the planned incident and problem resolution.	No exceptions noted.
			Inspected the supporting ticket and the incident report for a sample of incidents to determine that incidents were documented and tracked in a standardized ticketing system and updated to reflect the planned incident and problem resolution.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
System Operations				
CC7.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		Identified incidents are reviewed, monitored and investigated by an incident response team.	Inquired of the Director of Information Security regarding incident handling to determine that identified incidents were reviewed, monitored and investigated by an incident response team.	No exceptions noted.
			Inspected the incident response policy to determine that identified incidents were reviewed, monitored and investigated by an incident response team.	No exceptions noted.
			Inspected the supporting ticket and the incident report for a sample of incidents to determine that identified incidents were reviewed, monitored and investigated by an incident response team.	No exceptions noted.
CC7.4	The entity responds to identified security incidents by executing a defined incident response program to understand, contain, remediate, and communicate security incidents, as appropriate.	Identified incidents are analyzed, classified and prioritized based on system impact to determine the appropriate containment strategy, including a determination of the appropriate response time frame and the determination and execution of the containment approach.	Inquired of the Director of Information Security regarding incident handling to determine that identified incidents were analyzed, classified and prioritized based on system impact to determine the appropriate containment strategy, including a determination of the appropriate response time frame and the determination and execution of the containment approach.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
System Operations				
CC7.0	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
			Inspected the incident management policy to determine that identified incidents were analyzed, classified and prioritized based on system impact to determine the appropriate containment strategy, including a determination of the appropriate response time frame and the determination and execution of the containment approach.	No exceptions noted.
			Inspected the supporting ticket and the incident report for a sample of incidents to determine that identified incidents were analyzed, classified and prioritized based on system impact to determine the appropriate containment strategy, including a determination of the appropriate response time frame and the determination and execution of the containment approach.	No exceptions noted.
		Documented incident response and escalation procedures for reporting security incidents are in place to guide users in identifying, reporting and mitigating failures, incidents, concerns, and other complaints.	Inspected the incident response policy to determine that documented incident response and escalation procedures for reporting security incidents were in place to guide users in identifying, reporting and mitigating failures, incidents, concerns, and other complaints.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
System Operations				
CC7.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		Management reviews reports on a quarterly basis summarizing incident, root cause of incidents, and corrective action plans and as part of the review, management identifies the need for system changes and implementation of additional controls based on incident patterns and root causes.	Inspected the information security management systems assessment review and the change management board meeting minutes for a sample of quarters to determine that management reviewed reports on a quarterly basis summarizing incident, root cause of incidents, and corrective action plans and as part of the review, management identified the need for system changes and implementation of additional controls based on incident patterns and root causes.	No exceptions noted.
		The incident response and escalation procedures are reviewed at least annually for effectiveness.	Inspected the revision history of the incident response policies and procedures to determine that the incident response and escalation procedures were reviewed at least annually for effectiveness.	No exceptions noted.
		The incident response policies and procedures define the classification of incidents based on its severity.	Inquired of the Director of Information Security regarding incident handling to determine that the incident response policies and procedures defined the classification of incidents based on its severity.	No exceptions noted.
			Inspected the incident response policy to determine that the incident response policies and procedures defined the classification of incidents based on its severity.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
System Operations				
CC7.0	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
			Inspected the supporting ticket and the incident report for a sample of incidents to determine that the incident response policies and procedures defined the classification of incidents based on its severity.	No exceptions noted.
		Resolution of incidents are documented within the ticket and communicated to affected users.	Inquired of the Director of Information Security regarding incident handling to determine that resolution of incidents was documented within the ticket and communicated to affected users.	No exceptions noted.
			Inspected the incident response policy to determine that resolution of incidents was documented within the ticket and communicated to affected users.	No exceptions noted.
			Inspected the supporting ticket and the incident report for a sample of incidents to determine that resolution of incidents was documented within the ticket and communicated to affected users.	No exceptions noted.
		Incidents are documented and tracked in a standardized ticketing system and updated to reflect the planned incident and problem resolution.	Inquired of the Director of Information Security regarding incident handling to determine that incidents were documented and tracked in a standardized ticketing system and updated to reflect the planned incident and problem resolution.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
System Operations				
CC7.0	Criteria	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
			Inspected the incident response policy to determine that incidents were documented and tracked in a standardized ticketing system and updated to reflect the planned incident and problem resolution.	No exceptions noted.
			Inspected the supporting ticket and the incident report for a sample of incidents to determine that incidents were documented and tracked in a standardized ticketing system and updated to reflect the planned incident and problem resolution.	No exceptions noted.
		Roles and responsibilities for the design, implementation, maintenance, and execution of the incident response program are defined and documented.	Inspected the incident management policy to determine that roles and responsibilities for the design, implementation, maintenance, and execution of the incident response program were defined and documented.	No exceptions noted.
		The actions taken to address identified security incidents are documented and communicated to affected parties.	Inquired of the Director of Information Security regarding incident handling to determine that the actions taken to address identified security incidents were documented and communicated to affected parties.	No exceptions noted.
			Inspected the incident response policy to determine that the actions taken to address identified security incidents were documented and communicated to affected parties.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
System Operations				
CC7.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
			Inspected the supporting ticket and the incident report for a sample of incidents to determine that the actions taken to address identified security incidents were documented and communicated to affected parties.	No exceptions noted.
		Documented incident response and escalation procedures are in place to guide personnel in addressing the threats posed by security incidents.	Inspected the incident response policies and procedures to determine that documented incident response and escalation procedures were in place to guide personnel in addressing the threats posed by security incidents.	No exceptions noted.
CC7.5	The entity identifies, develops, and implements activities to recover from identified security incidents.	Backup restoration tests are performed on a semi-annual basis.	Inspected the completed backup restoration test to determine backup restoration tests were performed on a semi-annual basis.	No exceptions noted.
		Business continuity and disaster recovery plans are developed and updated on an annual basis.	Inspected the business continuity policy to determine that business continuity and disaster recovery plans were developed and updated on an annual basis.	No exceptions noted.
		Business continuity and disaster recovery plans are tested on an annual basis.	Inspected the completed business continuity and disaster recovery test results and the scheduled business continuity and disaster recovery test to determine that the business continuity and disaster recovery plans were tested on an annual basis.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
System Operations				
CC7.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		Management reviews reports on a quarterly basis summarizing incident, root cause of incidents, and corrective action plans and as part of the review, management identifies the need for system changes and implementation of additional controls based on incident patterns and root causes.	Inspected the information security management systems assessment review and the change management board meeting minutes for a sample of quarters to determine that management reviewed reports on a quarterly basis summarizing incident, root cause of incidents, and corrective action plans and as part of the review, management identified the need for system changes and implementation of additional controls based on incident patterns and root causes.	No exceptions noted.
		Change management requests are opened for incidents that require permanent fixes.	Inspected the change management policies and procedures to determine that change management requests were required to be opened for incidents that required permanent fixes.	No exceptions noted.
		The entity restores system operations for incidents impacting the environment through activities that include, but are not limited to: • Rebuilding systems • Updating software • Installing patches • Changing configurations	Inspected the information security policy and the change management policies and procedures to determine that the entity restored system operations for incidents impacting the environment through activities that included, but were not limited to: • Rebuilding systems • Updating software • Installing patches • Changing configurations	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
System Operations				
CC7.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		Data backup and restore procedures are in place to guide personnel in performing backup activities.	Inspected the backup policies and procedures to determine that data backup and restore procedures were in place to guide personnel in performing backup activities.	No exceptions noted.
		A business continuity and disaster recovery plan is documented to identify and reduce risks, limit the consequences of damaging incidents, and ensure the timely resumption of essential operations.	Inspected the business continuity and disaster recovery plans to determine that a business continuity and disaster recovery plan was documented to identify and reduce risks, limited the consequences of damaging incidents, and ensured the timely resumption of essential operations.	No exceptions noted.
		The business continuity and disaster recovery plan and procedures are updated based on disaster recovery plan test results.	Inspected the business continuity and disaster recovery plans and the completed business continuity and disaster recovery test results to determine that the business continuity and disaster recovery plan and procedures were updated based on disaster recovery plan test results.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Change Management				
CC8.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
CC8.1	The entity authorizes, designs, develops or acquires, configures, documents, tests, approves, and implements changes to infrastructure, data, software, and procedures to meet its objectives.	The ability to migrate changes into the production environment is restricted to authorized and appropriate users.	Inquired of the Director of Information Security regarding the ability to migrate changes into the production environment to determine that the ability to migrate changes into the production environment was restricted to authorized and appropriate users.	No exceptions noted.
			Inspected the list of users with the ability to implement changes into the production environment to determine that the ability to migrate changes into the production environment was restricted to authorized and appropriate users.	No exceptions noted.
		Code repository is utilized to help detect unauthorized changes within the production environment.	Inspected the code repository configurations to determine that a code repository was utilized to help detect unauthorized changes within the production environment.	No exceptions noted.
		The code repository is configured to notify IT personnel via e-mail alert when a change to the production application code files is detected.	Inspected the code repository notification configurations and an example alert generated from the code repository to determine that the code repository was configured to notify IT personnel via e-mail alert when a change to the production application code files was detected.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Change Management				
CC8.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		Documented change control policies and procedures are in place to guide personnel in the change management process.	Inspected the change management policies and procedures to determine that documented change control policies and procedures were in place to guide personnel in the change management process.	No exceptions noted.
		The change management process has defined the following roles and assignments: • Authorization of change requests • Development • Testing • Implementation	Inspected the change management policies and procedures to determine that the change management process defined the following roles and assignments: • Authorization of change requests • Development • Testing • Implementation	No exceptions noted.
		System changes are communicated to both affected internal and external users.	Inspected the entity's release note articles to determine that system changes were communicated to both affected internal and external users.	No exceptions noted.
		System changes are authorized and approved by management prior to implementation.	Inspected the supporting change ticket for a sample of operating system, database and application changes to determine that system changes were authorized and approved by management prior to implementation.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Change Management				
CC8.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		Prior code is held in the source code repository for rollback capability in the event that a system change does not function as designed.	Inspected the entity's code repository to determine that prior code was held in the source code repository for rollback capability in the event that a system change did not function as designed.	No exceptions noted.
		Development and test environments are physically and logically separated from the production environment.	Inspected the separate staging and production environments to determine that development and test environments were physically and logically separated from the production environment.	No exceptions noted.
		System change requests are documented and tracked in a ticketing system.	Inspected the supporting change ticket for a sample of operating system, database and application changes to determine that system change requests were documented and tracked in a ticketing system.	No exceptions noted.
		Back out procedures are documented within each change implementation to allow for rollback of changes when changes impair system operation.	Inspected the Product Planning and Development lifecycle procedures and the supporting ticket for a sample of application changes to determine that back out procedures were documented within each change implementation to allow for rollback of changes when changes impair system operation.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Change Management				
CC8.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		System changes are tested prior to implementation. Types of testing performed depend on the nature of the change.	Inspected the Product Planning and Development lifecycle procedures and the supporting ticket for a sample of system changes to determine that system changes were tested prior to implementation and types of testing performed depended on the nature of the change.	No exceptions noted.
		Documented change control policies and procedures are in place to guide personnel in implementing changes in an emergency situation.	Inspected the change management policies and procedures to determine that documented change control policies and procedures were in place to guide personnel in implementing changes in an emergency situation.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Risk Mitigation				
CC9.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
CC9.1	The entity identifies, selects, and develops risk mitigation activities for risks arising from potential business disruptions.	Management has defined a formal risk assessment process that specifies the process for identifying internal and external threats and vulnerabilities, evaluating and addressing risks and defining specified risk tolerances.	Inspected the risk management policy to determine that management defined a formal risk assessment process that specified the process for identifying internal and external threats and vulnerabilities, evaluating and addressing risks and defining specified risk tolerances.	No exceptions noted.
		A formal risk assessment is performed on at least an annual basis to identify internal and external threats and vulnerabilities that could impair system commitments and requirements.	Inspected the completed risk assessment to determine that a formal risk assessment was performed on an annual basis to identify internal and external threats and vulnerabilities that could impair system commitments and requirements.	No exceptions noted.
		Identified risks are rated using a risk evaluation process and ratings are approved by management.	Inspected the risk management policy to determine that identified risks were rated using a risk evaluation process and ratings were approved by management.	No exceptions noted.
		Risks identified as a part of the risk assessment process are addressed using one of the following strategies: • Avoid the risk • Mitigate the risk • Transfer the risk	Inspected the risk assessment and management policies and procedures and completed risk assessment to determine that risks identified as a part of the risk assessment process were addressed using one of the following strategies: • Avoid the risk • Mitigate the risk • Transfer the risk	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Risk Mitigation				
CC9.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		Management develops risk mitigation strategies, including the implementation of controls, to address risks identified during the risk assessment process.	Inspected the risk management policy to determine that management developed risk mitigation strategies, including the implementation of controls, to address risks identified during the risk assessment process.	No exceptions noted.
		Documented policies and procedures are in place to guide personnel in performing risk mitigation activities.	Inspected the risk management policy to determine that documented policies and procedures were in place to guide personnel in performing risk mitigation activities.	No exceptions noted.
		The entity has purchased insurance to offset the financial loss that could result from a critical security incident or exploitation of a vulnerability.	Inspected the insurance documentation to determine that the entity purchased insurance to offset the financial loss that could result from a critical security incident or exploitation of a vulnerability.	No exceptions noted.
		Identified third-party risks are rated using a risk evaluation process and ratings are approved by management.	Inspected the vendor management policy and the completed risk assessment to determine that identified third-party risks were rated using a risk evaluation process and ratings were approved by management.	No exceptions noted.
CC9.2	The entity assesses and manages risks associated with vendors and business partners.	A vendor risk assessment is performed on an annual basis which includes reviewing the activities performed by critical third parties.	Inspected the vendor risk assessment policies and procedures and the completed vendor risk assessment to determine that a vendor risk assessment was performed on an annual basis which included reviewing the activities performed by critical third parties.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Risk Mitigation				
CC9.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		Management has defined a formal risk assessment process that specifies the process for identifying internal and external threats and vulnerabilities, evaluating and addressing risks and defining specified risk tolerances.	Inspected the risk management policy to determine that management defined a formal risk assessment process that specified the process for identifying internal and external threats and vulnerabilities, evaluating and addressing risks and defining specified risk tolerances.	No exceptions noted.
		A formal risk assessment is performed on at least an annual basis to identify internal and external threats and vulnerabilities that could impair system commitments and requirements.	Inspected the completed risk assessment to determine that a formal risk assessment was performed on an annual basis to identify internal and external threats and vulnerabilities that could impair system commitments and requirements.	No exceptions noted.
		Identified risks are rated using a risk evaluation process and ratings are approved by management.	Inspected the risk management policy to determine that identified risks were rated using a risk evaluation process and ratings were approved by management.	No exceptions noted.
		Management obtains and reviews attestation reports and vendor questionnaires of vendors and third parties to evaluate the effectiveness of controls within the vendor or third party's environment.	Inspected the completed third-party attestation report for a sample of third parties that the entity has a relationship with to determine that management obtained and reviewed attestation reports of vendors and third parties to evaluate the effectiveness of controls within the vendor or third party's environment.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Risk Mitigation				
CC9.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		The entity has purchased insurance to offset the financial loss that could result from a critical security incident or exploitation of a vulnerability.	Inspected the insurance documentation to determine that the entity purchased insurance to offset the financial loss that could result from a critical security incident or exploitation of a vulnerability.	No exceptions noted.
		Management has defined a third-party vendor risk management process that specifies the process for evaluating third-party risks based on identified threats and the specified tolerances.	Inspected the vendor management policy to determine that management defined a third-party vendor risk management process that specified the process for evaluating third-party risks based on identified threats and the specified tolerances.	No exceptions noted.
		Management develops third-party risk mitigation strategies to address risks identified during the risk assessment process.	Inspected the vendor risk assessment policies and procedures and the completed risk assessment to determine that management developed third-party risk mitigation strategies to address risks identified during the third-party risk assessment process.	No exceptions noted.
		Identified third-party risks are rated using a risk evaluation process and ratings are approved by management.	Inspected the vendor management policy and the completed risk assessment to determine that identified third-party risks were rated using a risk evaluation process and ratings were approved by management.	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Risk Mitigation				
CC9.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
		The entity's third-party agreement outlines and communicates: • The scope of services • Roles and responsibilities • Terms of the business relationship • Communication protocols • Compliance requirements • Just cause for terminating the relationship	Inspected the master third-party agreement template and the executed third-party agreements for a sample of third parties to determine that the entity's third-party agreement outlined and communicated: • The scope of services • Roles and responsibilities • Terms of the business relationship • Communication protocols • Compliance requirements • Just cause for terminating the relationship	No exceptions noted.

TRUST SERVICES CRITERIA FOR THE SECURITY CATEGORY				
Risk Mitigation				
CC9.0	**Criteria**	**Control Activity Specified by the Service Organization**	**Test Applied by the Service Auditor**	**Test Results**
			Inspected the customer agreement template and executed customer agreement for a sample of customers to determine that the entity's third-party agreement outlined and communicated: • The scope of services • Roles and responsibilities • Terms of the business relationship • Communication protocols • Compliance requirements • Just cause for terminating the relationship	No exceptions noted.
		A formal third-party risk assessment is performed on an annual basis to identify threats that could impair system commitments and requirements.	Inspected the vendor management policy to determine that a formal third-party risk assessment was performed on an annual basis to identify threats that could impair system commitments and requirements.	No exceptions noted.

SECTION 5

OTHER INFORMATION PROVIDED BY THE SERVICE ORGANIZATION

SUMMARY OF TESTING EXCEPTIONS

Control Point	Control Activity Specified by the Service Organization	Test Applied by the Service Auditor	Test Results
CC1.1 CC1.2 CC1.4 CC1.5 CC4.1	Performance and conduct evaluations are performed for personnel on a quarterly basis.	Inspected the completed performance evaluation tracking spreadsheet for a sample of current employees to determine that performance and conduct evaluations were performed for personnel on a quarterly basis.	Testing of the control activity disclosed that a performance and conduct evaluation was not performed on a quarterly basis for nine out of 25 current employees sampled.
CC1.4	The entity evaluates the competencies and experience of candidates prior to hiring, and of personnel transferring job roles or responsibilities.	Inspected the interview notes and supporting communications for a sample of new hires to determine that the entity evaluated the competencies and experience of candidates prior to hiring, and of personnel transferring job roles or responsibilities.	Testing of the control activity disclosed that interview notes were not retained for one of the 15 new hires sampled. Subsequent testing disclosed that the one user did not hold a critical role and was confirmed to not be a user with privileged access to the production environment.
CC2.2	Current employees are required to read and acknowledge the information security policies and procedures and complete information security and awareness training on an annual basis.	Inspected the information security and awareness training completion confirmation for a sample of current employees to determine that current employees were required to read and acknowledge the information security policies and procedures and complete information security and awareness training on an annual basis.	Testing of the control activity disclosed that security awareness training was not completed timely for four out of 25 current employees sampled.